Shameless Consulting Ltd.
Information Security Management System (ISMS)

Created by IT Consultant:
Sampy Gill

Version: 5.2

May 8th, 2024

Version Control

Version	Revision Date	Description of Changes Made	Change Author
1.0	02/10/2024	Created working doc, created title page, started version control table	Jakob Marshall, Sampy Gill
1.2	02/17/2024	Added content to Introduction section, created Scope and Asset Management sections, added content to Scope section	Sampy Gill, Jakob Marshall
1.3	02/19/2024	Added content to Asset Management section	Isaac Whang
1.4	02/20/2024	Finalized content for Introduction, Scope, and Asset Management sections; created table of contents; added Letter of Thanks; added process flow diagram	Isaac Whang, Sampy Gill, Jakob Marshall
2.0	02/27/2024	Added Risk Management section	Jakob Marshall
2.1	03/03/2024	Added content to Risk Management sections	Jakob Marshall, Sampy Gill, Isaac Whang, Brian Ko
3.0	03/08/2024	Completed section 4.1	Isaac Whang
3.1	03/08/2024	Completed section 4.2 and 4.5	Brian Ko
3.2	03/08/2024	Completed section 4.3	Sampy Gill
3.3	03/08/2024	Completed section 4.4	Jakob Marshall
4.0	03/26/2024	Created Incident Outline	Jonathan Chao
4.1	04/02/2024	Completed section 5.1 and 5.2	Ruben Chavarria
4.2	04/05/2024	Completed section 5.3 and 5.4	Sampy Gill
4.3	04/05/2024	Completed section 5.5 and 5.6	Jonathan Chao, Sampy Gill
4.4	04/06/2024	Completed section 5.7, 5.8, and 5.9	Michelle Chen

5.0	05/03/2024	Completed section 6.0, Phishing Policy title page	Sampy Gill
5.1	05/05/2024	Completed Phishing Policy, began Patch Policy	Sampy Gill
5.2	05/07/2024	Completed Patch Policy and Procedure	Sampy Gill

Table of Contents

Executive Summary…….7
Letter of Thanks……...8
1.0 — Introduction……...9
1.1 ISMS Introduction…….9
1.2 Obligations…….9
1.3 Legal Responsibilities……..10
2.0 — Scope……...12
2.1 Scope Statement……...12
2.1.1 Activities and Processes……12
2.2 Scope Justification……...13
3.0 — Asset Management……...……14
3.1 Asset Definition……...14
3.2 Asset Identification and Classification……14
3.2.1 Asset Identification……...14
3.2.2 Asset Classification……..15
3.2.3 Implementing Classification Policies…….……..16
3.2.4 Documentation and Review……..……..……..17
3.3 Asset Ownership…….……17
3.3.1 Importance of Asset Ownership……..……..17
3.3.2 Assigning Asset Ownership……..……..……..17
3.3.3 Responsibilities of Asset Owners……...…..18
3.3.4 Training and Awareness……..……..……18
3.3.5 Audit and Review……..…….……..18
3.4 Asset Protection……...……18
3.4.1 Asset Developing Asset Protection Policies…….……18
3.4.2 Implementing Security Controls……..…….……19
3.4.3 Training and Awareness……..……..……19
3.4.4 Monitoring and Review……..……..……19
3.4.5 Response and Recovery……..……..……19
3.5 Asset Monitoring and Reviewing……...….20
3.5.1 Establishing Monitoring Mechanisms……..20
3.5.2 Review Processes……..20
3.5.3 Incorporating Feedback Loops…….21
3.5.4 Updating Asset Management Practices……21
3.6 Asset Management Records…….21
3.6.1 Importance of Asset Management Records……..22
3.6.2 Components of Asset Management Records……22
3.6.3 Maintaining and Accessing Asset Management Records…….22

3.6.4 Audit and Review…….23
3.7 Risk Management and Asset Criticality……..23
3.7.1 Identifying and Assessing Risks……...23
3.7.2 Determining Asset Criticality……...23
3.7.3 Risk Mitigation Strategies……24
3.7.4 Continuous Risk Monitoring……24
3.7.5 Communication and Documentation……24
3.8 Compliance and Legal Requirements……..24
3.8.1 General Data Protection Regulation (GDPR)……...25
3.8.2 California Privacy Rights Act (CPRA)……25
3.8.3 Payment Card Industry Data Security Standard (PCI DSS)…….25
3.8.4 Digital Personal Data Protection Act (DPDPA)…….……..26
3.8.5 Implementing Compliance Measures……...26
3.8.6 Continuous Compliance Monitoring……26
4.0 — Risk Management……..…….27
4.1 Definition and Purpose…….28
4.2 Methodology and Approach……29
4.3 Internal and External Factors Affecting Risk……..30
4.3.1 Quantitative Vs. Qualitative Risk Control……31
4.4 Purpose and Design of Risk Register……...32
4.4.1 Identifying and Describing Risks……..33
4.4.2 Identifying Threats and Vulnerabilities……34
4.4.3 Determining Likelihood of a Threat…….35
4.4.4 Classifying Impact of a Threat……..35
4.5 Risk Treatment Strategies……37
5.0 — Incident Reponse…….39
5.1 Benefits of Incident Management System……..39
5.2 Approaches to Incident Management System…….39
5.2.1 CMU Incident Response Plan……..39
5.2.2 NIST Special Publication 800-61 Revision 2……40
5.2.3 SANS Incident Response Framework……40
5.2.4 Recommended Approach……40
5.3 Pre-Incident Preparation……41
5.3.1 Incident Definition……..41
5.3.2 Incident Classification……41
5.3.2.1 Impact on CIA……...41
5.3.2.2 Classification Scheme……...…42
5.3.3 Incident Handling……42
5.3.4 Example Application……43
5.3.4.1 Detection and Analysis……43

5.3.4.2 Containment, Eradication Recovery…….43
5.3.4.3 Post-Incident Activity……44
5.3.4.4 Preparation……44
5.4 Identifying and Reporting……44
5.4.1 Security Forums……..…..45
5.4.2 Intrusion Detection System (IDS)…….……45
5.4.3 Security Incident and Event Management (SIEM)…….…..45
5.4.4 Disaster Incident……..….45
5.4.5 Law Enforcement Involvement…….…..46
5.5 Performance Metrics and Incident Response Lifecycle…….……46
5.5.1 Key Performance Indicators (KPIs)……..……46
5.6 Incident Documentation……..47
5.6.1 NIST Recommendations …….…...47
5.7 Disaster Recovery Plan……..…47
5.7.1 Backups and 123 Rule…….....47
5.7.2 Software Recommendations…….…48
5.8 CPMT Establishment……..…50
5.8.1 Decision Makers……..…….51
5.9 Potential Updates to Incident Response Lifecycle……51
6.0 — Policies and Controls……..53
6.1 Purpose…….54
6.2 Definitions……54
6.2.1 Policy Definition……..…54
6.2.2 Standards Definition…….54
6.2.3 Best Practice Definition……...55
6.2.4 Procedures Definition……..55
6.3 Types of Information Security Policies……55
6.4 Policy Recommendations…….56
6.4.1 Phishing Awareness and Email Security Policy……...56
6.4.2 Patch Management Policy……56
6.4.3 Data Encryption Policy……56
6.4.4 Disaster Recovery and Business Continuity……57
6.4.5 ISO 27001 Connection……57
Phishing Awareness and Email Security Policy……..59
Patch Management Policy……63
Phishing Awareness Training and Email Response Procedure……67
References……..71

Executive Summary

The Information Security Management System (ISMS) implemented at Shameless Consulting Limited serves as a comprehensive framework for managing and mitigating information security risks, safeguarding sensitive data, and ensuring the confidentiality, integrity, and availability of organizational assets. With the increasing growth of cyber threats and regulatory requirements, the ISMS plays a crucial role in strengthening Shameless's information security posture and fostering a culture of awareness. One of the primary areas of focus of the ISMS is the identification and mitigation of key risks that pose significant threats to Shameless Consulting Ltd information assets and operations. Our analysis provided insight into which assets are at risk as outlined in our risk register. Main risks are associated with personnel and outdated hardware operating at Shameless. Employee training and awareness is the main factor discussed in the ISMS. Human error has been the main culprit associated with information security compromisation and education nurtures a safe environment. Lack of knowledge has allowed very important data to be leaked, ultimately resulting in fines and loss of reputation. Outdated systems have allowed intruders to freely enter Shameless's systems, leading to more data leakage and financial loss. Known exploits allow for easy access, and it is heavily recommended that a policy is implemented to allow for proper patch updates. Another risk associated with Shameless is the lack of encryption to important data. As seen from the past, devices can be stolen and sensitive data was accessed due to this issue. End-to-end encryption ensures that data can't be intercepted and this is crucial for Shameless's business operations. Enhancing data security measures will allow for a stronger posture overall. A fourth risk associated with Shameless is the lack of preparedness in the incident of disaster. When an unexpected event disrupts services and operations, like a natural disaster, it is crucial for Shameless to have the proper measures set in place. Down time, as seen from the two days Shameless was not in service, can result in hundreds of thousands of dollars in losses. A Disaster Response Team would heavily minimize losses associated with this event. A fifth risk we've evaluated at Shameless is non-compliance with newer legal regulatory requirements. Shameless operates in multiple parts of the world, including California and the United Kingdom. Laws have been passed to encourage data protection, and Shameless has violated these numerous times. The California Privacy Rights Act (CPRA) can result in thousands of dollars in fines on each incident of data leakage. Examining the case where ~1000 clients data was leaked, this could've easily resulted in hundreds of thousands of dollars in financial loss. Furthermore, the General Data Protection Regulation (GDPR) in the UK can cause fines up to 20 million in Euros due to non-compliance of data measures. Overall, Shameless has many issues involving their information security measures. Here at Gill Limited, we will continuously work to improve the processes of Shameless through evaluation and implementation of practices and policies.

Letter of Thanks

To: The Team at Shameless Consulting Ltd.

Our entire team at Gill Limited is grateful for the opportunity to work alongside Shameless to craft solutions that not only benefit your company, but also those that your company serves. We are determined to help you navigate the hurdles you currently face as well as leave you with lasting procedures that can be applied well beyond the scope of this consultation. The goal is to build an Information Security Management System (ISMS) that implements policies and procedures specifically addressing your team's most pressing needs. This will ensure the long-term viability of your company and your mission as we work with you to make Shameless the absolute best line of defense for your customers against increasing cyber threats. Once again, we thank you for choosing Gill Limited to represent your business and security needs, and we look forward to working with you.

Sincerely,

Gill Limited

1.0 Introduction

1.1 ISMS Introduction

An ISMS is a document that comprehensively outlines the procedures an organization has in place to protect the assets the organization relies on to operate. This ISMS for Shameless Consulting, Ltd. (hereafter referred to as Shameless) serves to demonstrate the company's intent to improve its cybersecurity maturity and is a plan for these procedures. Having an ISMS helps Shameless maintain an effective roadmap of security policies so that in the instance they need to be used, the time it takes to react and recover appropriately is reduced. This, in turn, helps maintain shareholder and customer confidence and creates a reputation of responsibility and accountability.

This ISMS will go towards enforcing a top-down approach to cyber risk management and security policies in which upper management is the primary driver of pushing procedures to the lower levels of Shameless' business structure. Shameless benefits from this approach since the document creates cohesive, company-wide policies. It is also a holistic, structured, and methodical approach to security policies that benefit the company's long-term competitiveness. Finally, enforcing this ISMS document with robust procedures to protect, respond, and recover from vulnerabilities that target Shameless' assets can save the company from significant financial and reputational losses resulting from operational/network downtime and legal fines. Overall, the ISMS will mitigate the risk of loss for Shameless.

1.2 Obligations

At the most standard level, businesses must protect their information systems, meaning that reasonable security measures should be in place to safeguard assets such as customer data. An information security framework such as this ISMS is built on the three core principles of security: confidentiality, integrity, and availability (CIA). These principles are critical to understanding and enforcing appropriate information security policies. Confidentiality of information means that information can only be accessed by those who need it for their duties. Integrity is keeping data, like personal customer information, secure and encrypted. Availability refers to ensuring that resources are accessible when needed to minimize downtime, especially in case of a system failure.

According to the National Institute of Standards and Technology (NIST), a cybersecurity framework should have the following five functions: identification, protection, detection, response, and recovery. Referring to an organization's assets, it is imperative that you properly identify what you have and take steps to best protect and keep them operational. These standards benefit organizations because they allow for policies to be created that specifically cater to their

needs while remaining in line with information security standards and expectations. Using these as a base reference for current and future information security programs at Shameless can help guide the organization to fulfill its duties to its stakeholders. Both CIA principles and the five functions outlined by NIST guide the policies in this document.

The audit conducted by Gill Limited of Shameless revealed critical flaws and vulnerabilities of several assets that are essential to the operation of the business, some of which have already been exploited. Current issues such as network vulnerability, email server downtime, and loss of customer data can all be addressed by having an ISMS that is cohesive across the organization and easy to use for all employees. Implementing this ISMS is necessary for Shameless to continue operating as a business and avoid further financial losses and damage to its reputation. In addition to implementing the ISMS, Shameless' obligation extends further to continuously review and improve policies. Staying up-to-date with security policies ensures that the organization is proactively managing the risk of emerging cyber threats.

1.3 Legal Responsibilities

Shameless operates in three key markets: the UK, India, and the USA, all of which have their own legal regulations pertaining to privacy and personal data. Failure to comply with the consumer privacy laws of the countries the business operates within can result in significant legal fines and damage to the image of the company. Below is a list of regulations Shameless should focus its compliance efforts on.

<u>General Data Protection Regulation (GDPR)</u>

- GDPR compliance applies to all organizations that operate in the EU (including the UK) or collect or process data originating in the EU. The GDPR is based on C.I.A. principles of confidentiality, integrity, and availability of data. GDPR requires you to create a privacy policy that is in line with GDPR principles. The risk of not complying with GDPR is either £20,000,000 or 4% of revenue, whichever is greater.

<u>California Privacy Rights Act (CPRA)</u>

- Similar to the GDPR, the CPRA gives individuals in California greater privacy rights over their personal data. Failure to comply with the CPRA can lead to fines of $2,500 for each unintentional violation or up to $7,500 for each intentional violation or violations that involve children.

<u>Payment Card Industry Data Security Standard (PCI DSS)</u>

- PCI DSS compliance is a global industry standard of compliance for any organization that handles payment methods such as credit, debit, or other special cards. This is to reduce the risk of credit card fraud and to ensure payment

security. Failure to comply with PCI or the occurrence of a data breach can result in fines ranging from $5,000 to $100,000 per month.

Digital Personal Data Protection Act (DPDPa)

- DPDPa compliance applies to businesses operating inside of India, protecting the personal data rights of individuals in the country. Penalties for noncompliance can be $6,000,000 for any instance of a breach, and up to $30,000,000 if your company fails to take measures to protect data.

2.0 Scope

2.1 Scope Statement

This ISMS will be a comprehensive plan for all three Shameless office locations: Bridlington, New Delhi, and Los Angeles. The main location is the Bridlington office, where upper management and the IT department will both be analyzed. The satellite offices in New Delhi and Los Angeles will also be examined but with lesser emphasis.

The timeframe for our review and implementation is 12 months from the agreed-upon date. This will allow for an in-depth analysis of company security processes.

$700,000 has been allocated to allow for proper application of the ISMS. The majority of funds will be invested in the main Bridlington location.

2.1.1 Activities and Processes

The main focus of our review will include a full-fledged analysis of data acquisition and transfer protocols. Ensuring compliance with all legal obligations will avoid unnecessary fines and financial loss. Based on past data leaks and breaches, fines could pass well over $100,000 if governing agencies decided to press charges. Restructuring of past protocols is worth the financial investment as these fines will continue to accrue over time.

Furthermore, the focus will be on upgrading hardware and software throughout the entire company. Faulty systems and unpatched vulnerabilities allow outside actors to access confidential information. As stated this can lead to financial loss, but will also diminish company progress and create delays for improvement.

Staff training and awareness will be another goal of our ISMS initiative. Numerous employees have fallen victim to malicious phishing attacks, where a perpetrator disguises a link to steal information. Furthermore, attacks impacted the Domain Name System (DNS), where the title of the website was potentially hijacked by attackers. These attacks not only allow for the risk of theft but also impact the reputation of the company as a whole.

Potential staff upgrades and hiring will be reviewed as well. Many tasks are required for your company to operate efficiently and current employees have expressed their overwhelming experiences. Delegation of duties will allow for the ISMS to be implemented effectively and properly.

2.2 Scope Justification

Each location has faced challenges with network and data security, so it would not be adequate to focus on just the main Bridlington location. Specific issues associated with the satellite offices would likely be overlooked and unremediated if no analysis was performed. Data breaches and leaks have occurred numerous times, and it is essential to determine where and how these happened by looking at each location. Investment in these issues now will prevent fines and financial loss. In the company's current state, losses can total well into the millions, and we will continuously work to repair issues and save future assets. As of right now, all sites are connected to the same servers and data can freely flow throughout. Following our complete analysis, we will allocate funds to the correct locations to strengthen company processes entirely. The current similarities between the satellite offices and the main office will allow for the ISMS to provide a holistic framework for each office to follow as a guideline. Due to the larger size and overarching issues rooted at the main office, the ISMS will mainly emphasize solutions here. However, proactive adjustments will be made to account for differences in the Los Angeles and New Delhi locations, ensuring the goals of the ISMS remain intact. Given our timeframe of 12 months and budget of $700,000, we will successfully implement our plan, allowing for continuous security and success.

3.0 Asset Management

3.1 Asset Definition

According to the National Institute of Standards and Technology (NIST), an asset is defined as "the data, personnel, devices, systems, and facilities that enable the organization to achieve business purposes" (Stine et al., 2020). This definition highlights the necessity for a holistic approach to asset management, recognizing the integral role each asset plays in the operational and strategic capabilities of the organization.

3.2 Asset Identification and Classification

Asset identification and classification should adhere to the guidelines set out in NIST SP 800-53 Rev. 5 and NIST SP 800-60 Vol. 1 & 2. NIST SP 800-60 provides a detailed guide for mapping types of information and information systems to security categories, aiding in the classification process based on potential impact levels (NIST SP 800-60 Vol. 1 & 2).

3.2.1 Asset Identification

The first step, asset identification, involves identifying every asset that contributes to the organization's operations and objectives. This comprehensive inventory spans various categories, including but not limited to:

- **Digital Software:** Software applications, databases, and information systems
- **Physical Assets:** Hardware Devices, Networking Equipment, and Physical Security Systems.
- **Intangible Assets:** Intellectual Property, Company Reputation, Brand Value, and Procedures.
- **Human Assets:** Employee's roles, skills, and responsibilities.

Effective means of cataloging assets include automated discovery tools, physical audits, and consultations with department heads to ensure no asset goes unrecorded. Each asset is documented with specific details such as name/asset tag, description, location, and asset owner, establishing a foundation for the subsequent classification process and providing accountability for asset management.

Below is a chart outlining how we categorized Shameless' assets, including examples of what falls within them:

Category	Examples
People	CEO, IT Head, Network Manager, etc.
Procedures	Bring Your Own Device (BYOD), Password Policy
Data	Customer Data, Credit Card Data
Software	File Transfer Management, Web Server
Hardware	Desktop Computers, Personal Laptops, Mobile Devices
Networking Components	Router, Active Directory Server, etc.

Figure 1 - Asset Categorization

3.2.2 ASSET CLASSIFICATION

Following Asset Identification, assets must be classified according to parameters such as their value, security, and criticality to the organization's mission and objectives. This classification is essential for the prioritization of assets and determining the level of protection each asset requires. Key factors in asset classification include:

- **Confidentiality:** The degree to which the asset must be protected from unauthorized access.
- **Integrity:** The importance of maintaining the accuracy and completeness of the asset.
- **Availability:** The necessity of the asset being accessible to authorized users when required.

Assets are typically classified as public, internal, confidential, and secret, based on the above criteria. This categorization helps in applying the appropriate security controls and in conducting risk assessments.

Public

- Description: Public assets are those that can be disclosed or made accessible to anyone without any risk to the organization. These assets have no requirements for confidentiality.
- Confidentiality: Low - Public assets are intended for open distribution and do not require protection from unauthorized access.
- Integrity: Variable - Depending on the nature of the public asset, the importance of maintaining accuracy may vary. However, alterations generally pose minimal risk to the organization.

- Availability: Variable - Availability requirements can vary; some public information might need to be readily accessible, while for other types of public assets, availability might be less critical.

Confidential

- Description: Confidential assets include information that, if disclosed without authorization, could harm the organization's operations, reputation, or competitive advantage. Examples might include financial records, employee personal information, or business contracts.
- Confidentiality: High - Strong controls are required to prevent unauthorized access and ensure that access is limited to individuals who need the information to perform their job functions.
- Integrity: High - It is crucial to maintain the accuracy and completeness of these assets to prevent errors, fraud, or loss.
- Availability: High - These assets often need to be readily accessible to authorized users to support timely decision-making and business processes.

Secret

- Description: Secret assets are of the highest sensitivity and criticality, where unauthorized disclosure could result in severe legal, financial, or security implications. This might include proprietary technology, strategic plans, or security keys.
- Confidentiality: Very High - The most stringent protection measures are necessary to guard against any unauthorized disclosure.
- Integrity: Very High - Ensuring the integrity of these assets is paramount, as any alteration could have disastrous consequences for the organization.
- Availability: High - While protecting confidentiality and integrity is the top priority, these assets must also be accessible to a very limited group of authorized users when required.

By categorizing assets into these classifications based on confidentiality, integrity, and availability, Shameless can effectively prioritize its security measures. This approach allows the organization to allocate resources efficiently, focusing on protecting the most sensitive assets while still maintaining adequate security across all levels of information.

3.2.3 IMPLEMENTING CLASSIFICATION POLICIES

To effectively classify assets, organizations should develop and implement classification policies that detail the criteria and processes for categorizing assets. These policies should also specify the roles and responsibilities of asset owners in maintaining the classification and ensuring that security controls are appropriately applied.

3.2.4 DOCUMENTATION AND REVIEW

All identified and classified assets should be documented in an asset register or inventory management system. This documentation must be regularly reviewed and updated to reflect new acquisitions, disposals, or changes in classification.

3.3 ASSET OWNERSHIP

Asset ownership refers to the assignment of responsibility for an asset to an individual or department within the organization. This responsibility includes the management of the asset's security, compliance, utilization, and lifecycle management. The owner is typically someone with a direct stake in the asset's functionality and security, such as an IT manager for IT assets or a Human Resources manager for employee data. The identification of asset owners and the inclusion of ownership details in security planning are crucial steps highlighted in NIST SP 800-18 Rev. 1. This publication serves as a guide for developing security plans that effectively incorporate asset ownership, ensuring accountability and proper management (NIST SP 800-18 Rev. 1).

3.3.1 IMPORTANCE OF ASSET OWNERSHIP

The importance of asset ownership revolves around three key factors for the organization's success:

- **Accountability:** Establishing clear asset ownership ensures accountability for the protection and maintenance of the asset. It clarifies who is responsible for implementing security controls and managing risks associated with the asset.
- **Security and Compliance:** Asset owners are tasked with ensuring their assets comply with relevant laws, regulations, and standards such as GDPR. They must be aware of any specific requirements for data protection, privacy, and industry-specific regulations.
- **Lifecycle Management:** Asset Owners oversee the entire lifecycle of their assets, from acquisition and deployment to maintenance, and eventually disposal. This oversight includes ensuring the asset is updated, patched, and replaced whenever necessary

3.3.2 ASSIGNING ASSET OWNERSHIP

Organizations should identify potential asset owners based on their roles, expertise, and the asset's relevance to their department or function. For example, the CISO (Chief Information Security Officer) might be responsible for cybersecurity policies, while the CFO (Chief Financial Officer) might be responsible for financial data. Once assigned, asset ownership details should be documented, including the owner's ID tag, role, and specific responsibilities regarding the asset. This documentation should be accessible and regularly updated as changes occur.

3.3.3 RESPONSIBILITIES OF ASSET OWNERS

- **Risk Assessment:** Asset Owners are responsible for conducting or participating in risk assessments for their assets to identify vulnerabilities and threats.
- **Implementing Controls:** Based on the risk assessment, asset owners must ensure that appropriate security controls are in place and functioning properly.
- **Monitoring and Review:** Continuous monitoring of the asset's security posture and regular reviews are essential to adapt to new threats and changes within the organization.

3.3.4 TRAINING AND AWARENESS

Organizations must provide training and resources to asset owners to ensure they understand their responsibilities, the security landscape, and best practices for asset management. This training should cover topics such as data protection laws, security controls, incidence response, and risk management.

3.3.5 ASSET REVIEWS AND AUDITS

Regular reviews and audits of asset ownership and management practices help ensure that assets are being managed effectively and that owners are fulfilling their responsibilities. These reviews can also identify opportunities for improvement in the organization's asset management processes.

3.4 ASSET PROTECTION

Asset protection is a critical component of an Information System Management System (ISMS), focusing on implementing appropriate safeguards to ensure the confidentiality, integrity, and availability of assets. This process involves deploying a mix of physical, technical, and administrative controls tailored to the classification and criticality of each asset. Asset protection strategies must be aligned with the organization's overall risk management framework, and they should address potential threats and vulnerabilities that could impact asset security. To protect assets effectively, organizations should implement the controls outlined in NIST SP 800-53 Rev. 5.

3.4.1 DEVELOPING ASSET PROTECTION POLICIES

The foundation of asset protection is the development of comprehensive policies that outline the appropriate security measures and controls applicable to asset categories. These policies should be informed by the asset classification process to ensure that more sensitive and critical business assets receive higher levels of protection. A few key elements of asset protection policies include:

- **Access Control:** Define who is given access to which assets and under what conditions. Strong authentication and authorization mechanisms to control access to digital and physical assets are necessary.
- **Encryption:** Use encryption to protect the confidentiality and integrity of data, both stored and transmitted, especially for sensitive or critical information.
- **Physical Security:** Secure physical locations housing critical assets with controls such as surveillance cameras, security personnel, and access control systems to prevent unauthorized access and physical damage.
- **Environmental Controls:** Protect assets from environmental threats such as fire, flooding, and power outages with appropriate detection, prevention, and backup systems.

3.4.2 IMPLEMENTING SECURITY CONTROLS

After establishing properly tailored asset protection policies, the next step is implementing the specified security controls. This implementation should be guided by best practices and standards, such as the NIST SP 800-53, which provides a catalog of security and privacy controls for scalable information systems. Security controls should be selected based on their effectiveness in mitigating identified risks to assets and their feasibility within the organization's operational environment. A few key controls include but are not limited to:

- **Regular Software Updates and Patch Management:** Keep all software and network systems updated to protect against known vulnerabilities such as the MOVEit transfer vulnerability.
- **Antivirus and Malware Protection:** Deploy antivirus and anti-malware solutions to detect and mitigate threats to digital assets.
- **Backup and Recovery:** Implement regular data backup procedures and establish an incident recovery plan to ensure the availability of critical data and systems at all times.

3.4.3 TRAINING AND AWARENESS

A crucial aspect of asset protection is ensuring that all employees are aware of their roles and responsibilities in safeguarding assets. Security awareness training programs should cover the organization's asset protection policies, the importance of adhering to security controls, and the procedures for reporting security incidents or vulnerabilities to the appropriate authorities.

3.4.4 MONITORING AND REVIEW

Asset protection measures must be continuously monitored and reviewed to ensure their effectiveness and to adapt to new threats. This includes regular security assessments,

audits, and the use of monitoring tools to detect potential security breaches. Reports from these activities should inform future updates to asset protection practices and policies.

3.4.5 RESPONSE AND RECOVERY

Finally, establish incident response and recovery procedures to quickly address security breaches or failures in asset protection controls. These procedures should outline steps for containing incidents, assessing their impact, restoring operations, and communicating with stakeholders.

3.5 ASSET MONITORING AND REVIEW

Asset monitoring and review are crucial for maintaining the confidentiality, integrity, and availability of assets within an ISMS. This continuous process ensures that asset protection measures remain effective over time, adapting to new threats, vulnerabilities, and changes within the organization. NIST SP 800-137 provides a comprehensive framework for information security continuous monitoring (ISCM), emphasizing the need for ongoing assessment of control effectiveness and the security state of information systems. This approach is vital for the effective monitoring and review of asset management practices (NIST SP 800-137).

3.5.1 ESTABLISHING MONITORING MECHANISMS

Effective asset monitoring involves the implementation of mechanisms and tools designed to detect changes, threats, or incidents that could impact the security of assets. These mechanisms vary depending on the type of asset but generally include:

- **Network Monitoring Tools:** These are tools that can monitor network traffic and detect unusual patterns or potential security breaches affecting digital assets.
- **Physical Security Systems:** These include surveillance systems, motion detectors, and access logs to monitor for any unauthorized access or tampering with physical assets.
- **Software and System Logs:** Analyze logs from operating systems, applications, and security devices for any signs of malicious activity or policy violations.
- **Vulnerability Scanning and Penetration Testing:** Regularly conduct vulnerability scans and red and blue team penetration tests to identify and address security weaknesses in IT assets.

3.5.2 REVIEW PROCESSES

The review process is necessary to ensure that all assets and their protection measures are continually aligned with the organization's risk posture and compliance requirements. This involves:

- **Asset Inventory Updates:** Periodically update the asset inventory to reflect new acquisitions, changes, or disposals in existing assets. This ensures that the asset register remains accurate and comprehensive.
- **Risk Assessment Revisions:** Reassess risks associated with assets whenever there are significant changes in the threat landscape, business processes, or asset characteristics. Adjust protection measures based on the outcomes of these risk assessments.
- **Policy and Control Evaluations:** Regularly review asset protection policies and controls for their effectiveness and compliance with regular requirements. This may involve internal audits or third-party assessments.

3.5.3 INCORPORATING FEEDBACK LOOPS

Feedback mechanisms are essential for refining the asset monitoring and review process. this includes gathering insights from:

- **Incident Reports:** Analyze security incidents to identify root causes and improve asset protection strategies.
- **Employee Feedback:** Encourage staff to report security concerns or suggestions related to asset management. This can provide valuable insights into potential vulnerabilities or improvement opportunities.
- **Audit Findings:** Use findings from internal and external audits to identify gaps in asset management practices and compliance issues.

3.5.4 UPDATING ASSET MANAGEMENT PRACTICES

Based on the results from monitoring and review activities, organizations should update their asset management practices to address identified issues, enhance security controls, and improve overall effectiveness. This includes but is not limited to:

- **Adjusting Classification Levels:** Reassess the classification of assets as their criticality or sensitivity changes.
- **Modifying Protection Measures:** Update security controls to address new vulnerabilities or incorporate advanced protection technologies.
- **Improving Response Plans:** Refine incident response and recovery plans based on lessons learned from security incidents and recovery exercises.

3.6 ASSET MANAGEMENT RECORDS

Maintaining comprehensive and accurate asset management records is essential within an ISMS as these records serve as the foundation for effective asset identification, classification, protection, monitoring, and review processes. Maintaining detailed records of assets, including their management and protection measures, is supported by the controls in NIST SP 800-53 Rev.

5. For the documentation related to the sanitization and disposal of information system media, NIST SP 800-88 Rev. 1 offers guidelines that highlight the importance of record-keeping in asset management (NIST SP 800-53 Rev. 5; NIST SP 800-88 Rev. 1).

3.6.1 IMPORTANCE OF ASSET MANAGEMENT RECORDS

Asset Management Records are crucial for several reasons, including:

- **Accountability**: Establishing clear accountability and responsibility for the maintenance and security of assets.
- **Risk Management:** Detailed records support the risk assessment process by providing necessary information about the asset's characteristics, locations, and criticality to the organization.
- **Compliance:** Proper documentation helps in demonstrating compliance with regulatory requirements and standards.
- **Incident Response:** In the event of a security incident, asset records can facilitate a quick and effective response.

3.6.2 COMPONENTS OF ASSET MANAGEMENT RECORDS

According to NIST guidelines in NIST Special Publication (SP) 800-53, "Security and Privacy Controls for Federal Information Systems and Organizations," asset management records should include, but not limited to:

- **Asset Identification:** Unique identifiers (i.e. asset tags) and descriptive information (i.e. name, type, model).
- **Classification and Sensitivity:** The classification level of the asset is based on its sensitivity, criticality, and impact on the organization if compromised.
- **Ownership and Accountability:** Details of the asset owner and any other stakeholders responsible for the asset's management.
- **Location:** The physical or logical location of the asset within the organization's environment.
- **Protection Measures:** A summary of the security controls and protection measures applied to the asset.
- **Status and Lifecycle Information:** The current status of the asset (active, in maintenance, decommissioned) and significant lifecycle events (acquisitions, upgrades, disposals).

3.6.3 MAINTAINING AND ACCESSING ASSET MANAGEMENT RECORDS

NIST SP 800-53 also recommends the implementation of practices for the ongoing maintenance and protection of asset management records in the following ways:

- **Regular Updates:** Asset records should be updated regularly to reflect changes in asset status, ownership, or classification.
- **Accessibility:** Records must be accessible to authorized personnel for management, operational, and audit purposes while being protected from unauthorized access.
- **Backup and Recovery:** Ensure that backup copies of asset management records are created and stored securely to prevent loss of information.

3.6.4 AUDIT AND REVIEW

Consistent with NIST guidelines, organizations should periodically audit their asset management records for accuracy and completeness. This can involve cross-referencing records with physical audits, system inventories, and other documentation sources to identify discrepancies or outdated information.

3.7 RISK MANAGEMENT AND ASSET CRITICALITY

Risk Management and assessing the criticality of assets are crucial elements within the ISMS. This process involves identifying, evaluating, and prioritizing risks associated with organizational assets, and implementing appropriate measures to mitigate those risks. By understanding the criticality of each asset, an organization can allocate its resources more effectively and ensure that the most crucial assets receive the highest levels of protection.

3.7.1 IDENTIFYING AND ASSESSING RISKS

Risk Identification involves recognizing potential threats that could exploit vulnerabilities in assets, thereby impacting the organization's ability to achieve its objectives. The NIST provides a comprehensive guide in its NIST SP 800-30, "Guide for Conducting Risk Assessments" publication. NIST SP 800-30 outlines a systemic approach to identifying risks including:

- **Threat Identification:** Understanding the various sources of threats (i.e. cybercriminals, internal disasters, system failures) that could impact assets.
- **Vulnerability Assessment:** Identifying weaknesses in assets that could be exploited by threats.
- **Impact Analysis:** Evaluating the potential consequences of threats exploiting vulnerabilities, considering factors such as the confidentiality, integrity, and availability of assets.

3.7.2 DETERMINING ASSET CRITICALITY

The criticality of an asset is determined based on its importance to the organization's operations and the potential impact of its loss or compromise. Criticality assessments help in prioritizing assets and focusing risk management efforts where they are most

needed. NIST SP 800-53 suggests categorizing assets and information systems based on the impact levels of confidentiality, integrity, and availability, which can be adapted to assess asset criticality.

3.7.3 RISK MITIGATION STRATEGIES

Once risks are identified and assets have been prioritized based on their criticality, the next step is to develop and implement risk mitigation strategies. These strategies might include:

- **Applying Security Controls:** Selecting and implementing appropriate security controls from NIST SP 800-53 to protect critical assets against identified risks.
- **Risk Transfer:** Using insurance or contracts to transfer the financial impact of risks to third parties.
- **Risk Avoidance:** Changing business processes or asset usage to avoid certain risks altogether.
- **Risk Acceptance:** Acknowledging that certain risks are unavoidable or that the cost of mitigation exceeds the potential impact, and accepting the residual risk.

3.7.4 CONTINUOUS RISK MONITORING

Risk Management is an ongoing process that requires continuous monitoring to detect new risks and evaluate the effectiveness of implemented mitigation strategies. NIST SP 800-137 “Information Security Continuous Monitoring (ISCM)” provides guidelines for establishing a continuous monitoring strategy that includes assessing control effectiveness and impact levels over time.

3.7.5 COMMUNICATION AND DOCUMENTATION

Effective risk management involves clear communication and documentation of identified risks, criticality assessments, decisions made, and actions taken to mitigate risks. This ensures that stakeholders are informed and confident in the organization, and creates a clear record for audit and review purposes.

3.8 COMPLIANCE AND LEGAL REQUIREMENTS

Ensuring compliance with legal, regulatory, and contractual standards is a critical component of the ISMS. This process involves understanding the specific legal and regulatory landscape of the organization’s operations and assets and implementing measures to meet these requirements. Adherence to these standards not only protects the organization from legal and financial fines but also strengthens its security and reputation. Specifically, the organization should focus on compliance measures with the General Data Protection Regulation (GDPR), California Privacy

Rights Act (CPRA), Payment Card Industry Data Security Standard (PCI DSS), and Digital Personal Data Protection Act (DPDP).

3.8.1 GENERAL DATA PROTECTION REGULATION (GDPR)

The GDPR is a comprehensive data protection law that applies to all organizations operating within the EU and the UK, as well as those outside the EU that process data of EU residents. The GDPR emphasizes the confidentiality, integrity, and availability of personal data requiring organizations to:

- Implement appropriate technical and organizational measures to ensure data protection.
- Develop and maintain a privacy policy that complies with GDPR principles.
- Obtain clear consent for data processing, provide data access rights to individuals, and report data breaches within 72 hours.

Failure to comply with GDPR can lead to significant fines of up to €20 million or 4% of annual global turnover, whichever is greater.

3.8.2 CALIFORNIA PRIVACY RIGHTS ACT (CPRA)

The CPRA enhances the privacy rights of California residents, offering protections similar to GDPR. It requires businesses to:

- Provide transparency about data collection, usage, and sharing practices.
- Allow consumers to opt out of the sale or sharing of their personal information.
- Implement measures to protect personal information against security breaches.

Failure to comply with CPRA can result in fines of $2,500 per unintentional violation and $7,500 per intentional violation, with higher penalties for violations involving children's data.

3.8.3 PAYMENT CARD INDUSTRY DATA SECURITY STANDARD (PCI DSS)

PCI DSS is a global security standard for organizations that handle branded credit cards from major card schemes. It generally mandates:

- The implementation of strong access control measures.
- The maintenance of a vulnerability management system.
- Regular monitoring and testing of network security.
- The protection of cardholder data both in storage and transmission.

Failure to comply with PCI DSS can lead to fines ranging from $5,000 to $100,000 per month, depending on the severity and duration of the non-compliance, and may also result in the revocation of card processing privileges.

3.8.4 DIGITAL PERSONAL DATA PROTECTION ACT (DPDPA)

India's DPDPA aims to protect the personal data rights of individuals within India, requiring organizations to:

- Implement comprehensive data protection measures.
- Obtain consent for data processing and ensure data accuracy.
- Report data breaches in a timely manner.

Failure to comply with DPDPA can result in penalties of up to $6 million for breaches and up to $30 million for failing to take preventive measures against data breaches.

3.8.5 IMPLEMENTING COMPLIANCE MEASURES

Organizations must develop and implement comprehensive policies and procedures to ensure compliance with these regulations. This involves:

- Conducting regular risk assessments to identify potential compliance gaps.
- Implementing data protection measures tailored to the specific requirements of each regulation.
- Training employees on compliance requirements and data collection and protection best practices.
- Establishing incident response plans to address data breaches and other compliance incidents promptly.

3.8.6 CONTINUOUS COMPLIANCE MONITORING

To maintain compliance, organizations should engage in continuous monitoring of their data collection and protection practices and regulatory changes. This includes regularly reviewing and updating security policies, conducting audits to assess compliance, and adjusting practices as necessary to address new regulatory requirements or changes in the business and legal environment.

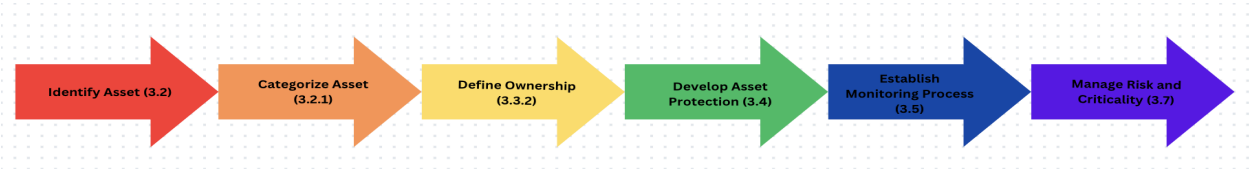

Figure 2 - Proactive Asset Flow Chart (for more information, visit sections referenced)

4.0 Risk Management

4.1 Definition and Purpose

Incorporating an Information Security Management System (ISMS) into the operational fabric of Shameless necessitates a cornerstone emphasis on risk management. This systematic and structured approach underpins the organization's efforts to safeguard its most vital assets against an ever-evolving array of cyber threats. At its core, the risk management (RM) process involves identifying, assessing, evaluating, and mitigating potential risks that could compromise the confidentiality, integrity, and availability (CIA) of the organization's information assets. The importance of having a risk management process is multifold; it serves not only as a protective measure but also as a strategic tool that enables Shameless to operate efficiently, maintain its competitive edge, and comply with regulatory and legal requirements.

The integration of the Plan-Do-Check-Act (PCDA) cycle into the risk management process is instrumental in fostering an environment of continuous improvement. This iterative process begins with the:

- **Plan** phase, where Shameless sets the context for risk management, including establishing risk criteria and conducting comprehensive risk assessments. This phase lays the groundwork for identifying and analyzing risks, which in turn informs the development of risk treatment plans.
- The **Do** phase sees implementing these plans and applying targeted strategies and controls to mitigate identified risks efficiently.
- During the **Check** phase, Shameless will engage in ongoing monitoring and review of the risk management process and the effectiveness of the implemented controls. This critical evaluation ensures that risk mitigation efforts are aligned with the organization's security objectives and are effectively reducing risk to acceptable levels.
- Finally, the **Act** phase involves taking corrective and preventative actions based on insights gained from the monitoring activities, aimed at refining and enhancing the risk management process.

Compliance with ISO 27001 Clauses 6.1.2 and 6.1.3a is central to ensuring that Shameless's risk management process is robust, systemic, and aligned with best practices in information security. These clauses mandate the establishment of a comprehensive framework for identifying, analyzing, and treating information security risks, including setting clear risk criteria, conducting consistent risk assessments, and selecting appropriate risk treatment options based on assessment results. By adhering to these standards, Shameless ensures its risk management process is capable of protecting against threats to information security, while also being flexible and adaptable to the changing risk landscape. More information on ISO 27001 clausal adherence is available in subsection 4.5.

A risk management process is crucial for several reasons. It provides a proactive approach to identifying potential risks and vulnerabilities before they can impact the organization, enabling timely and effective risk mitigation strategies. Furthermore, a structured RM process helps prioritize risks based on their potential impact on the organization, ensuring that resources are allocated efficiently to address the most critical threats. Moreover, it supports regulatory compliance, reducing the likelihood of legal and financial penalties associated with data breaches and other security incidents. Ultimately, having an RM process in place not only protects Shameless' valuable information assets but also supports its strategic goals, resilience, and long-term success in the face of cybersecurity challenges.

4.2 Methodology And Approach

Methodology:

- Identify assets and potential threats and vulnerabilities associated with them.
- Assess the likelihood and impact of each identified risk, considering existing controls
- Assign weighted scores to each risk based on its likelihood, impact, and the effectiveness of existing controls.
- Prioritize risks based on their weighted scores, criticality, and potential impact on the organization or project
- Develop and implement risk treatment strategies to mitigate or eliminate high-priority risks.
- Regularly monitor and review the risk register, updating it as new risks emerge or existing risks change. Adjust risk treatment strategies accordingly.

Approach:

Identify assets and classify them with the following details:

- Criticality (color): This column could indicate the criticality level of each risk using a color scheme
- Asset ID: A unique identifier for each asset within the organization
- Description: A brief description of the asset associated with the risk
- Weighted Score: A score that combines impact and likelihood of risk occurring
- Asset Value: The estimated value or importance of the asset to the organization
- Threat: The potential source of harm or adverse event that could exploit vulnerabilities in the asset
- Vulnerability 1: The first vulnerability associated with the asset
- Vulnerability 1 Explanation: A detailed explanation of the first vulnerability
- Vulnerability 1 Likelihood: The likelihood of the first vulnerability being exploited
- V1 Current Control: Current control measures in place to mitigate the first vulnerability
- V1 Current Control %: The effectiveness of the current control measures in percentage

- Uncertainty Value: Assessment of the uncertainty surrounding the risk estimation for the second vulnerability
- V2 Risk Rating: The risk rating associated with the second vulnerability, considering likelihood and impact
- Overall Risk Rating: The overall risk rating for the asset, considering all identified vulnerabilities
- Risk Treatment Strategy: Proposed strategies or actions to manage or mitigate the identified risks
- Recommended Control: Specific control measures recommended to address the identified risks
- ISO 27001 Control: Identification of controls from the ISO 27001 standard that can be applied to mitigate the identified risks

We chose to use NIST overall due to its comprehensive framework and widespread adoption in the cybersecurity industry. NIST provides a robust set of guidelines and standards for managing and securing information systems.

For controls and certain risk management aspects, we opted to utilize ISO (international organization for Standardization) standards, pertaining to the ISO section 5, 6, 7, and 8 standards. These standards are associated with Leadership, Planning, Support, and Operation. ISO standards offer a globally recognized framework for establishing, implementing, maintaining, and continually improving an information security management system. ISO's focus on controls and risk management complements NIST's broader approach, allowing for a more nuanced and thorough cybersecurity strategy.

Comparatively, OCTAVE is a risk assessment methodology developed by the CERT coordination center at Carnegie Mellon University. While OCTAVE offers a structured approach to identify and prioritize information security risks, it may not provide the same level of comprehensive guidance as NIST or ISO.

NIST benefits Shameless the most due to its thoroughness, credibility, and alignment with industry best practices. Shameless has cited poor network security protocols and internal network management. NIST's extensive documentation provides a utility of training and protocol resources to improve Shameless's network security and detailed guidance on various aspects of cybersecurity from risk management to incident response.

4.3 Internal and External Factors Affecting Risk

Based upon our investigation of Shameless' processes and procedures, we have determined that many different factors impact the risk of assets. Following our interview sessions with staff and

personnel, numerous components of the current system can lead to company losses. Below is a list of internal and external factors we have determined to be important when considering risk:

Internal Factors:

- **Lack of Employee Training**
    - The Senior Talent Advisor at Shameless has cited a lack of employee training protocols. Current strategies include sharing "unrelated YouTube videos" along with no formal phishing training.
    - Shameless has cited the infiltration of the "Emotet" malware due to phishing attacks sent to higher-level management. Furthermore, the personal information of over 1000 clients was uploaded to Reddit due to a phishing email. Data is a very important asset Shameless has to monitor to allow for successful business operation.
- **Outdated Systems and Services**
    - The Network Manager at Shameless has explicitly stated the lack of updated network components. It was claimed that the firewalls can't function due to being out of date and unsupported. The email server being run is from 2013 while the Windows system being used is from 2012. Multiple vulnerabilities and exploits are available online, giving hackers the ability to freely compromise systems with ease.
    - Shameless has directly cited the "increase in application-layer attacks that are breaching the organization's firewalls." Furthermore, recent losses of data were directly correlated "to hardware failure." It is known that these issues in outdated systems have led to direct company losses, and we will continuously work to improve this infrastructure.
- **Lack of Incidence Response**
    - A Help Desk and Operations Operative employee explained how they are supposed to be in charge of incident response, but cites the non-existence of a system. A ticketing system was mentioned as a possibility to help determine attacks and resolutions. This would substantially help mitigate future threats and exploits.
    - Numerous attacks have been cited by Shameless, but exploit methods can't be determined to a certainty. It can only be assumed what got attacked and how. This lack of incident response doesn't allow for proper remediation efforts. With a proper system put in place, the risk for future attacks will decrease and proper business operations can continue

External Factors:

- **Cyber Threat Landscape**

- The main external factor impacting the risk of assets is the growing threat of hackers and cybercriminal organizations. A study conducted by Duke University has concluded that nearly ~80% of U.S. businesses have been successfully hacked "in an attempt to steal, change or make public important data." Furthermore, it was cited that these attacks occurred as a "direct result of fewer resources being dedicated to data security at these firms." Based upon our investigation, we have determined that Shameless is at a high risk from these attacks.

- **Reputational Risks**
  - The perception of Shameless among its stakeholders plays a crucial role in shaping the company's reputation and brand image. Negative publicity resulting from cybersecurity incidents, data breaches, or privacy violations can tarnish Shameless' reputation and impact stakeholder trust, leading to financial losses and diminished market competitiveness.
  - Shameless has cited the loss of personal information that was leaked to the public. It was only discovered after being released on social media. This can seriously damage reputation and potentially turn away prospective customers. Not only this, but employees may feel unsafe with the data they share with the company. This can lead to them potentially leaving the company, causing disruption in business processes.
- **Regulatory Compliances**
  - Shameless has to follow specific data protection regulations based on the company's location. This includes the GDPR, the CPRA, the PCS DDI, and the DPDPA. More information about these regulations can be found above under section 3.8. Potential fines can easily range in the millions, and following the data leaks and lack of protocols, Shameless gives an easy case for policy enforcers.
  - Each of these regulations requires proper controls and their implementations. Shameless currently lacks any of these. We will work continuously to ensure that your company is properly aligned with all these requirements, diminishing the risk of unnecessary punishments and financial losses.

4.3.1 QUANTITATIVE VS. QUALITATIVE RISK CONTROL

Quantitative risk control involves the use of numerical data and statistical techniques to quantify and analyze risks in terms of actual values/estimates, financial impact, and other measurable parameters. By quantifying risks in terms of probabilities and numerical values, organizations can make informed decisions about risk management. For example, Shameless has a lack of training towards social engineering schemes. A quantitative approach to assessing risk would be to initially quantify the amount of employees falling for these attacks. Following the implementation of a training process, the same results would be recorded and then compared to the previous assessment. This would provide a

quantifiable result that could be easily compared.

Qualitative risk control focuses on assessing and managing risks based on subjective criteria, such as likelihood, impact, and severity. It involves identifying potential risks, analyzing their characteristics, and prioritizing them based on their perceived significance to the organization. Qualitative approaches allow for flexibility in risk assessment and management, enabling organizations to adapt to changing circumstances and emerging threats. For example, Shameless has numerous assets with different levels of importance to the company's operations. These assets can be defined to align with the current interests of Shameless, allowing for prioritization and significance based on what the business needs.

By integrating quantitative and qualitative approaches, Shameless can develop a comprehensive risk management framework that enhances its resilience to external threats while improving decision-making processes. Quantitative methods can provide insights into the likelihood and financial impact of specific risk scenarios, such as data breaches and hardware disruptions. Qualitative methods can help Shameless prioritize risks, identify key vulnerabilities, and communicate with stakeholders. This approach would be beneficial for addressing subjective factors such as regulatory compliance requirements and public perception.

4.4 Purpose and Design of Risk Register

The risk register is an addition to the asset register provided in conjunction with this report and described in greater detail in section 3.0 above. Its primary purpose is to provide a holistic view of your organization's information security posture. It also helps create a structured, systematic approach to identifying, assessing, and controlling risks associated with your assets. Most importantly, the risk register for your assets is intended to be consistently revisited and updated to reflect improvements in reducing your assets' risks.

Currently, Shameless has no systemized approach to identify and assess threats and vulnerabilities of its information assets. Gill Ltd. has designed a risk register with Shameless' needs in mind. From our interview sessions with the staff of Shameless, we discovered that there is no system in place to prioritize projects which often leads to the oversight of major issues relating to information security. While the risk register is not a task prioritization system itself, it is an effective starting point for determining which major risks should be addressed most immediately.

Due to the importance of your organization being able to repeat the RM process within the risk register, the subsections below provide greater detail on how to make use of this.

4.4.1 IDENTIFYING AND DESCRIBING RISKS

A risk is the potential for loss if a threat to an asset is acted upon. For example, Shameless does not have a data backup policy, so if the database experiences downtime, the risk of data loss is high. Descriptions of risk for each asset category outlined in the asset register are as follows:

- **People:** Risks to employees include human error, unauthorized access, or other internal threats. Employees can compromise the CIA of an organization's assets.
- **Procedures:** Risks of procedures encompass inadequate or outdated policies. Weak policies can leave an organization unprepared to respond to incidents and leave its systems open to unauthorized access and data theft.
- **Data:** Risks related to data include data breaches, loss, and leakage especially if proper security measures are not in place.
- **Software:** Risks of software include unpatched applications/programs that could be exploited, thus compromising the stability of an organization's IT infrastructure.
- **Hardware:** Risks associated with hardware relate to physical theft or unauthorized access to physical devices containing sensitive data.
- **Networking Components:** Risks of networking components include outdated or unsecured routers, servers, and firewalls that leave the network open to attackers or more susceptible to downtime and thus lost revenue.

All of the risks above have the potential to cause significant loss (both financial and reputational) to your organization, so it is important to have an organized risk register and RM process so that you can 1) identify and assess the criticality of risks associated with certain assets, and 2) implement effective controls to reduce the risk.

The risk register our team is providing lays out a quantitative approach to assessing each asset's risk. To use the risk register, all assets from the asset register are combined onto a separate spreadsheet with each asset in its own row. Begin the risk assessment process for an asset by multiplying the "weighted score" of the asset from the asset register by 20 to create a risk-rating scheme on a 100 scale. This will make distinguishing between levels of risk criticality easier for your organization. Risk is ultimately determined by the asset value and the likelihood of the threat occurring. See the table below for an example of how to start the risk register.

Asset ID	Description	Weighted Score	Asset Value

HW-100	Company/Personal Laptop	3.0	60 (3.0 x 20)

Figure 3 - Risk Register asset value determination

4.4.2 IDENTIFYING THREATS AND VULNERABILITIES

The first step in the RM process is to identify the risk of a given information asset. This involves the recognition, enumeration, and documentation of risks which begins in the risk register. Given that a risk is the potential of a certain threat's vulnerability being exploited, these two factors—threats and vulnerabilities—are what is enumerated in the risk register.

A threat is the potential for an attack to occur. For information assets in the risk register, identify threats by determining an event that either has occurred within the past year, or that could occur in the future given its vulnerabilities. A threat is more likely to occur if it is not protected or mitigated against. Typically, threats to information assets can be classified as one of the following (also as seen in the provided risk register):

- Compromises to Intellectual Property
- Unauthorized Trespass
- Forces of Nature
- Human Error or Failure
- Information Extortion
- Deviation in Quality of Service

A vulnerability is an exploitable weakness of a certain threat. To identify a vulnerability of a certain threat, assess the asset for flaws that could be exploited to compromise information security. See the table below for the continued example from Figure 3 for identifying a threat and vulnerability in the risk register.

Threat	Vulnerability	Vulnerability Explanation
Information Extortion	Weak data protection measures	Lack of encryption and strong password policies make company devices more susceptible to data theft.

Figure 4 - Threat and Vulnerability Identification in the Risk Register

If controls are not put in place to protect against an asset's vulnerabilities, the CIA of the organization's systems can be compromised. For example, in Figure 4 above, if weak

data protection measures are taken advantage of on a company laptop, sensitive data could be stolen which compromises all three pillars of CIA.

4.4.3 DETERMINING LIKELIHOOD OF A THREAT

In the context of RM, the likelihood of a threat is a rating of the probability of a specific vulnerability being exploited. The risk register provided by Gill Ltd. uses a quantified scale to rank the likelihood of a threat event occurring:

Likelihood	Description	% Likelihood of Occurrence within 12 Months
0.0	Not applicable	0%
0.2	Rare	5%
0.4	Unlikely	25%
0.6	Moderate	50%
0.8	Likely	75%
1.0	Certain	100%

Figure 5 - Threat likelihood ranking scheme

From the information Gill Ltd. gathered during staff interviews and consulting observations, our team determined most of Shameless' assets to be either likely or certainly impacted by a threat event within the next 12 months. Continuing with the asset example from Figures 3 and 4, the vulnerability of "weak data protection measures" is given a likelihood value of 1.0 due to the fact that Shameless currently does not have any data protection measures in place which has already resulted in compromises to its data's CIA.

Ultimately, the determination of the likelihood of a threat is at the discretion of the organization, but it should still be made on sound judgment and available evidence.

4.4.4 CLASSIFYING IMPACT OF A THREAT

The overall impact of a threat is how your organization can distinguish between the criticality of each threat and thus prioritize controls for the most critical. Gill Ltd. made this a quantified approach in which the risk rating of two (2) vulnerabilities for each asset threat are averaged.

Five factors go into calculating the risk rating of each vulnerability: asset value (detailed in section 4.4.1), vulnerability likelihood (detailed in 4.4.3), vulnerability current control, the percent value of the control, and the percent value of uncertainty. A current control is

anything currently in place that protects the security of the asset, such as employee training, or a firewall. The control is then quantified into a percentage which is determined by the organization. If there is no control, the percentage value will be 0%. Gill Ltd. determined some controls, like the existing firewall, to be 5%, because while its function is to provide protection, its current state is ineffective. Complete protection would be 100%. Uncertainty value takes into account the unknowns which could include gaps of knowledge, or estimation errors of the control value.

Taking these factors into account, the formula Gill Ltd. used to determine the risk of a vulnerability follows, as does a representation of this in the risk register:

(Likelihood x Value) - (Control % x Value) + (Uncertainty % x Value) = Risk

Asset Value	Vuln. Likelihood	Vuln. Current Control	Vuln. Control %	Uncertainty Value	Vuln. Risk Rating
60	1.0	None	0%	15%	69.0

Figure 6 - Risk rating system for risk register

While the above is calculated for only one vulnerability, the second vulnerability for this asset was given a risk rating of 50.4. Averaged out, the overall risk of this asset is 59.7. See the table below for where this rating would stand regarding criticality.

Rank	Description	Example
0-10	No applicable threat	No impact
10-20	Insignificant (Accepted Risk Level)	No interruption, no exposed data
20-40	Minor	Multi-minute interruption, no exposed data
40-60	Moderate	Multi-hour interruption, minor exposure of data. System disruption would cause a moderate problem to the organisation and possibly other networks or systems
60-70	Major	One-day interruption, exposure of data
70-100	Severe	Multi-day interruption, major exposure of sensitive data. Damage / disruption to the system would cause the most impact on the organisation, mission, and other networks and systems

Figure 7 - Risk criticality rating scale

Color coding based on risk rank helps to identify which assets pose the greatest risk and potential impact to your organization.

4.5 Risk Treatment Strategies

- Mitigation: Implement measures to reduce the likelihood or impact of the risk. This could involve strengthening security controls, improving processes, or enhancing training and awareness programs
- Defense: Implement measures to stop and completely prevent a risk from occurring
- Training and Awareness: Invest in employee training and awareness programs to educate staff about potential risks, their consequences, and how to prevent or respond to them effectively
- Compliance: Ensure compliance with relevant laws, regulations, and industry standards to mitigate legal and regulatory risks.
- Investment in Technology: Deploy advanced technologies and tools to enhance security, detect potential risks, and automate risk management processes
- Improvement of Controls: Enhance existing controls or implement new controls to address vulnerabilities and reduce the likelihood or impact of risks.

ISO 27001 Controls **6.1.2 - Information Security Risk Assessment** **6.1.3 - Information Security Risk Treatment**	**Related Document Section**
6.1.2a - establishes and maintains information security risk criteria that include: 1. The risk acceptance criteria; and 2. Criteria for performing information security risk assessments	3.7.3, 4.3.1, 4.4
6.1.2b - ensures that repeated information security risk assessments produce consistent, valid and comparable results	4.4
6.1.2c - identifies the information security risks: 1. Apply the information security risk assessment process to identify risks associated with the loss of confidentiality, integrity and availability for information within the scope of the information security management system; and 2. Identify the risk owners	4.3
6.1.2d - analyses the information security risks:	4.3

1. Assess the potential consequences that would result if the risks identified in 6.1.2 c) 1) were to materialize; 2. Assess the realistic likelihood of the occurrence of the risks identified in 6.1.2 c) 1); and 3. Determine the levels of risk	
6.1.2e - evaluates the information security risks: 1. Compare the results of risk analysis with the risk criteria established in 6.1.2 a); and 2. Prioritize the analyzed risks for risk treatment	4.3
6.1.3a - select appropriate information security risk treatment options, taking account of the risk assessment results	See risk register columns V, W, and X

5.0 Incident Response

5.1 Benefits of Incident Management System

The formation of an Incident Management System will provide Shameless with a set of procedures to follow in the event of a computer security incident. A consistent and detailed Incident Management System will assist personnel to minimize loss or theft of information and disruption of services caused by incidents. As previous sections of this ISMS have detailed, the loss, theft, and disruption of information and services may cause great financial consequences to the organization. To minimize financial and data loss, the Incident Management System has been designed to allow for constant updates, in order to tackle new threats as they arise. In this manner, the organization's defenses against computer-related attacks are further reinforced and improved upon.

The Incident Management System facilitates the response to computer security incidents in a number of ways. Perhaps the most important, it defines what exactly an incident is, and dictates methods to both detect incidents, and confirm their verity. Depending on the incident, methods of containment, data recovery, and evidence retrieval and handling procedures are detailed. The collection of evidence allows for the prosecution of malicious actors, preventing them from orchestrating further exploitation of computer systems and disruption to the organization's business processes. In addition to procedural instructions, the Incident Management System encourages reflection upon its own capacity to adequately address computer security incidents. If deficiencies are found in the processes outlined in the Incident Management System, the high-level management of Shameless, equipped with the counsel of IT Department Managers, are encouraged to revise or replace policies in order to improve the organization's security environment.

5.2 Approaches to Incident Management System

5.2.1 CMU Incident Response Plan

The Carnegie Mellon University Incident Response Plan utilizes a six step process in order to organize the identification and response to a computer security incident. The steps are as follows: preparation, detection, containment, investigation, remediation, recovery. The CMU IRP defines events, incidents, and references the ISO for data classification schemas. The CMU IRP is a very general template, dictating what an organization's Incident Management System should accomplish, but does not necessarily discuss the best or recommended practices to achieve such an end.

5.2.2 NIST Special Publication 800-61 Revision 2

The NIST framework combines individual steps mentioned in both the CMU Incident Response Plan, and SANS Incident Response Framework, into a four step procedure. Those steps are as follows: (1) Preparation, (2) Detection and Analysis, (3) Containment, Eradication and Recovery, (4) Post-Incident Activity. NIST provides detailed yet general instructions for the formation of a highly-functioning and modifiable Incident Management System. This is represented through NIST's inclusion of various sub topics such as Incident Prioritization, Identification of Attacking Hosts, and Using Collected Incident Data, all of which come together to provide a clear, detailed, and linear system to follow in the event of a computer security process.

5.2.3 SANS Incident Response Framework

The SANS Framework is, similar to the CMU IRP, a six step procedure that outlines the various stages responding to a computer security incident. The level of detail it presents is somewhere between the CMU and NIST frameworks. What is particularly useful are the "cheat sheets" SANS provides. These include useful command line prompts in both Windows and Linux, to see various processes and their associated services: additionally, a checklist is included to neatly summarize all sections of the framework.

5.2.4 Recommended Approach

It is recommended that Shameless utilizes the system established by NIST SP 800-61 Revision 2. There are multiple reasons for this recommendation. Firstly, the number of staff available to respond to computer security incidents is minimal. For this reason, NIST is particularly appealing, due to the fact that it envelops the detection and analysis procedures, as well the containment, eradication and recovery sections, into two steps respectively. The conjunction of these steps enables the small number of responders (called a CPMT, see Section 7.3) to be more efficient, handling one task at a time in all its entirety, rather than handling or revisiting multiple tasks, all at different stages in the Incident Response Lifecycle. A graphic of the Incident Response Lifecycle as determined by NIST is included below:

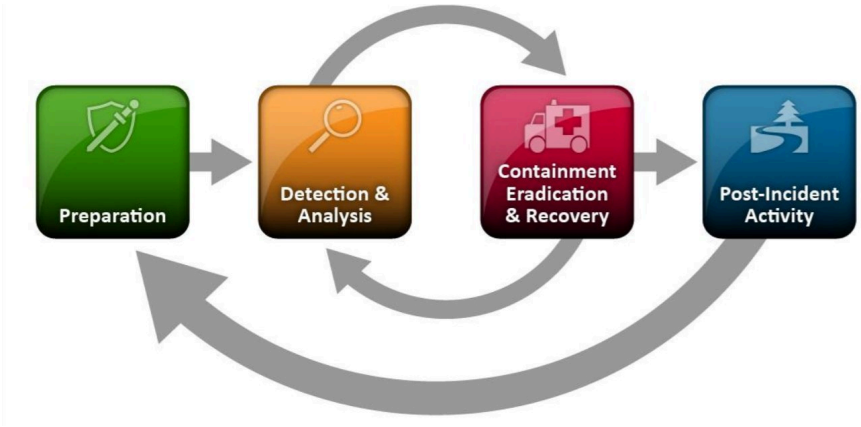

Figure 8. Incident Response Life Cycle
(NIST SP 800-61r2)

Both the NIST and SANS frameworks for Incident Response acknowledge that, sometimes, it is necessary to revise previously determined processes or procedures in order to confront a new issue. For example, the recovery of a device affected by a virus may lead to the detection of a different form of malware on that device, a keylogger!

5.3 Pre-Incident Preparation

5.3.1 INCIDENT DEFINITION

A business network is constantly undergoing many different processes and services. According to the NIST SP 800-61 Revision 2, "any observable occurrence" in a system can be defined as an event. This includes anything from a server receiving a web page request to a user sending out an email. On the other hand, an incident is defined as "a violation or imminent threat of violation of computer security policies, acceptable use policies, or standard security practices." For example, this could be when an attacker obtains sensitive data or if malware gets installed. These two definitions must be understood and differentiated to allow for proper focus in order to minimize downtime and loss.

5.3.2 INCIDENT CLASSIFICATION

5.3.2.1 IMPACT ON CIA

A guiding model to understanding cybersecurity measures is the CIA triad. Confidentiality represents the protection of assets from unauthorized access. Integrity ensures that all data is trustworthy while being complete and unaltered. Availability means that data and services are accessible when they need to be.

When an incident compromises even one of these categories, business operations could be halted and Shameless can experience serious financial losses due to downtime or applicable fines. Our incident response plan ensures that these violations will be minimized with an emphasis on timely remediation.

5.3.2.2 CLASSIFICATION SCHEME

Following the classification scheme provided by NIST SP 800-61 Revision 2, incidents will be divided into categories based on impact. This will allow for the prompt allocation of necessary resources, efficiently delegating tasks in order for Shameless to continuously operate. Below is a table that defines how incidents are differentiated:

Category	Definition
None	No effect to the organization's ability to provide all services to all users
Low	Minimal effect; the organization can still provide all critical services to all users but has lost efficiency
Medium	Organization has lost the ability to provide a critical service to a subset of system users
High	Organization is no longer able to provide some critical services to any users

Figure 9. Functional Impact Categories (NIST SP 800-61r2)

5.3.3 INCIDENT HANDLING

Based on which category an incident falls under, tasks to resolve the issue will be delegated to necessary departments. All potential incidents should always be reported to the Help Desk. Here, the incident will be reviewed and determined to be invalid or valid. In the case the incident falls in the “none” category, it will be reported and placed into archival. If the incident is determined to be of “low impact”, the Help Desk will resolve the issue. In the case of a “medium impact” incident, the Help Desk will work towards a resolution with the aid of the CPMT if needed. For any “high impact” incidents, the task will be delegated and handled entirely by the CPMT to ensure maximum efforts. Below is a working flow chart outlining the incident handling process:

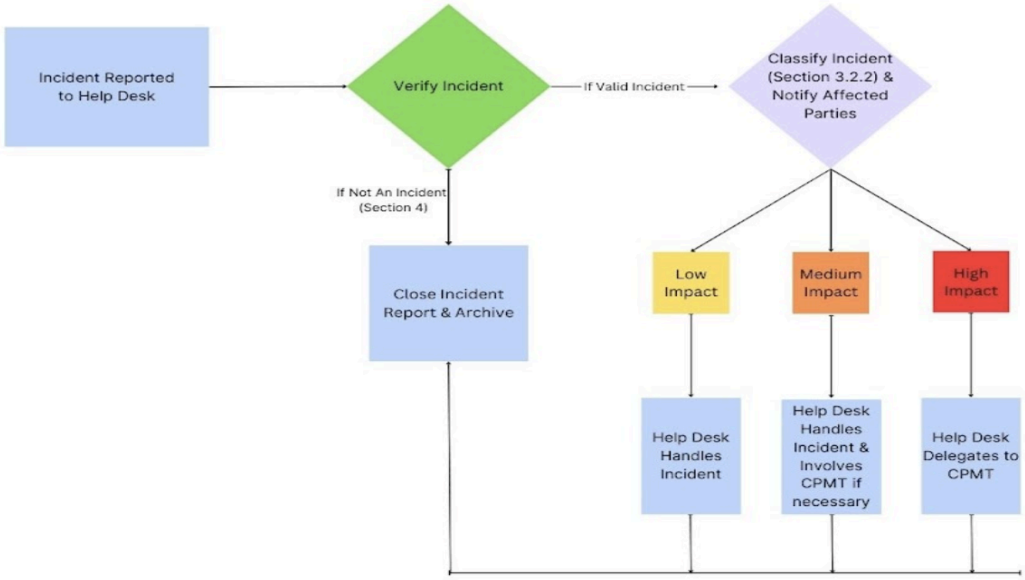

Figure 10. Incident Handling Flow Diagram

5.3.4 EXAMPLE APPLICATION

5.3.4.1 DETECTION AND ANALYSIS

Consider the incident in which 1,000 of Shameless client's had their data leaked on Reddit. At first detection, a report should be filed with the Help Desk. Qualified and pertinent employees on the CPMT (in this case, the DPO and CTO) should analyze the legitimacy of the event (in this case, leaked data). Upon finding that the leaked information is legitimate, the incident enters the containment, eradication, and recovery stage.

5.3.4.2 CONTAINMENT, ERADICATION, RECOVERY

In this stage, the CPMT must "fix" the issue. While the breach of personally identifiable information (PII) cannot be undone, steps can be taken to limit the potential of further breaches. For example, the situation can be contained by changing passwords to prevent further unauthorized access to PII. This can be achieved through the Active Directory server by someone with an administrator account, such as the Network Manager or CTO. To recover from the breach, Shameless must also notify the affected individuals whose data was leaked. This action is required by regulatory bodies such as the GDPR and CPRA.

5.3.4.3 POST-INCIDENT ACTIVITY

This phase includes a follow-up investigation/incident report, conducted by the CPMT. The incident report requires a holistic understanding of the potential causes of the data leak. Staff at Shameless did execute this step, which revealed useful information about policies at the organization. The investigation found that a third party support techinican's email account was brute forced. This suggests that Shameless may need to consider a policy which only allows contracting with organizations that have respectable and transparent security policies. The report continues, stating that the database administrator's password was stolen. Additionally, this password was only 5 characters in length, and used for multiple logins. This fact suggests the necessity for password training, and the creation and strict enforcement of a password policy, which includes stipulations on password length, character diversity, as well as unique passwords for each login page.

5.3.4.4 PREPARATION

The solutions revealed by the above investigation must be implemented in order to protect the organization from related incidents. Because the post-incident investigation revealed deficiencies in training and policy, the CPMT should work closely with the HR manager to implement adequate training and update or create policies accordingly. If the post-incident investigation revealed deficiencies in networking hardware, such as routers or firewalls, the CPMT should work closely with the Network Manager to remedy vulnerabilities.

5.4 IDENTIFYING AND REPORTING

There are numerous methods that can be used to successfully identify and report potential signs of an incident. These signs can fall into two categories: precursors and indicators. A precursor shows that an incident may occur in the future. An indicator shows that an incident did in fact occur or is currently occurring. Precursors are much less common than indicators, but the event of detection can help prepare or at least allow more activity monitoring involving the perceived target. Indicators are much more common and can include events from suspicious login attempts to deviations in network traffic flows. It is the responsibility of the Help Desk to properly identify each incident into these categories for proper allocation of time and resources. Below are different sources that can be used to help with these efforts:

5.4.1 SECURITY FORUMS

A local security forum can be created to allow for quick and efficient communication between employees and the Help Desk. If an employee detects suspicious activity in the network or on their system, they can immediately alert the Help Desk through this forum. Different categories can be created to facilitate and organize potential incidents, allowing for streamlined processes and timely remediation. Furthermore, the forum can include industry discoveries and recommendations regarding specific issues. However, this can be overwhelming and potentially cause delays depending on the amount of tickets coming through.

5.4.2 INTRUSION DETECTION SYSTEM (IDS)

An IDS deployed throughout the Shameless network will continuously monitor for suspicious activity and potential security breaches, recording important data regarding them. This includes time of event, relevant IP addresses, type of attack, etc. These records should always be stored and backed-up in case of an actual attack to allow for proper evaluation and prevention in the future. This system will provide large amounts of data, but can be hard to decipher and organize.

5.4.3 SECURITY INCIDENT AND EVENT MANAGEMENT (SIEM)

Similar to an IDS, a SIEM records important data regarding suspicious activity and potential security breaches. However, it can analyze and aggregate large chunks of data and logs, making it much more practical from a user perspective. Compliance and user-behavior can also be recorded, allowing for in-depth recommendations. It can be altered in order to be more applicable to the specific needs of Shameless. Alerts can be sent to the Help Desk based on calculated risk formulas that determine the potential of an incident. Compared to an IDS, this provides a less overwhelming workload on employees with a user-friendly interface, efficiently allowing for proper identification and remediation efforts. For a company with Shameless' size and budget, we recommend beginning with the service provided by Grafana Cloud. It begins as free and cost increases based on demand by Shameless. Depending on the needs of the company, IBM's QRadar SIEM can also be implemented. Pricing is around ~$550 per month, but provides all functionalities available by a SIEM as it is an industry-leading product.

5.4.4 DISASTER INCIDENT

An incident can be defined as a disaster if the company can't contain/control it's impact or if the damage is so severe that the company can't recover in a timely fashion. A

Disaster Recovery Team (DRT) should be developed in the case that this occurs. It will include knowledgeable employees that are capable of understanding and handling this stressful situation. For Shameless, this will likely involve the Network Manager, the Data Protection Officer, and Help Desk Operatives, at the least. The main goal of the DRT is to reestablish operations from the impacted location. Natural and human-made disasters must be differentiated to allow proper resource management. Furthermore, it should be known whether the disaster occurred rapidly or slowly. A rapid disaster is difficult to prepare for, but having knowledge about a slow-onset disaster can prevent future incidents of the same nature.

5.4.5 LAW ENFORCEMENT INVOLVEMENT

The CPMT and DRT should become acquainted with relevant law enforcement representatives and develop a line of communication in the event of an incident that violates civil or criminal law. The conditions of when to report an incident, how to report an incident, and proper evidence handling should all be discussed and established beforehand. NIST recommends that a designated individual shall be assigned as the primary point-of-contact between the company and law enforcement. For Shameless, the Data Protection Officer will likely be that line of communication. However, it should be noted that the alert of law enforcement will likely lead to public knowledge of the incident. This can harm company reputation and should be resorted to only when necessary.

5.5 PERFORMANCE METRICS AND INCIDENT RESPONSE LIFECYCLE

Performance metrics are useful for the assessment of company performance, which leads nicely to finding which areas need the most attention. ISO 27001 recommends keeping track of KPIs, or Key Performance Indicators. KPIs allow a quick and efficient way to communicate the importance and current landscape of security for management at Shameless, and thus are important in keeping the organization secure in the future.

5.5.1 KEY PERFORMANCE INDICATORS (KPIs)

KPIs include data about security, such as: Number of vulnerabilities addressed within a month of their discovery, Number of security events in the last month, Length of time between incident and detection, Percentage of assets that have had a cost benefit analysis performed for, etc. KPIs are important to analyze, and taking them into account will help Shameless align with clause 9.1 of ISO 27001. To continually analyze and address metrics/KPIs, we recommend that Shameless employ Servicenow's ITSM product. ITSM tools facilitate a healthy workplace environment, as they offer an all-in-one solution to

facilitating tasks and operating workflows. ITSM can assist with asset management, change management, config management, continual improvement management, incident response, and management of knowledge. Essentially, an ITSM provides a general location for requests to be handled and for incidents to be dealt with. We also recommend the use of Snort, a Linux open-source IDS (Intrusion Detection System) and IPS (Intrusion Prevention System). Snort also provides real-time network traffic analysis, which is useful for logging. Networking tools such as Snort or alternatives like Suricata allow Shameless to monitor who enters the network, along with preventing/ detecting data exfiltration. In the case of a DDoS, Snort can identify the attack and be configured to automatically block such attempts to bring down the network. In the case of a worm, Snort can be used to detect and stop the attack from propagating through the system.

5.6 INCIDENT DOCUMENTATION

Incidents can be documented using ITSM and Snort. Reference section 3.4 for more information on how incidents could be documented. As listed in section 2, we foremost recommend the use of the NIST SP 800-61 Revision 2 framework, and thus believe that incidents should be documented in accordance with the framework.

5.6.1 NIST RECOMMENDATIONS

NIST recommends that an issue tracking database be used to keep track of all information related to incidents, including a chain of custody document for evidence and audio logs for completeness. NIST recommends the use of either a logbook or digital camera and audio recorder. We recommend that Shameless employ the digital camera to record evidence of incidents.

5.7 DISASTER RECOVERY PLAN

5.7.1 BACKUPS AND 123 RULE

The disaster recovery plan will focus on implementing backup strategies, particularly adhering to the 3-2-1 rule, to mitigate risks and ensure business continuity in the event of data loss or disaster. The 3-2-1 rule is a widely-recognized industry standard for data backup and recovery. It includes maintaining at least three copies of data, storing these copies on at least two different types of storage media, and keeping at least one copy off the physical company site in the case of natural disaster.

The backup strategy plan will include steps for infrastructure setup, data classification, backup frequency, storage media, offsite backup, backup testing, and maintenance

procedures. A centralized backup infrastructure will be established in the company that consists of hardware and software solutions such as adequate backup servers and network infrastructure. These should include encryption mechanisms that will secure the data being held.

Next, data will be classified based on its criticality business operations, and backed up according to its ranking. Backup frequency will then be determined by the level of critical data in the business, and the rate of data change. Incremental backups should be conducted daily or multiple times a day depending on the level of data criticality, and full backups are recommended to be conducted every month. These backups should then be stored in a combination of storage media such as disks, drives, and cloud storage onsite to create redundancy of data in case one medium fails or becomes corrupted, and a secure offsite backup location that is geographically distant from the primary site should store another copy of all the data backed up at the primary site. This can include the company sites in India and USA that are besides the main office site in the UK.

These backup sites should be regularly tested in its backup and recovery procedures to ensure their reliability in protecting the data. Simulated disaster scenarios are recommended to be conducted in order to validate the effectiveness of the disaster recovery plan. Finally, continual routine maintenance checks should be conducted at the main office site including software and hard checks to ensure the health of company systems and backup processes.

5.7.2 SOFTWARE RECOMMENDATIONS

Software Function	Software Names	Software Description
Backup & Recovery Solution	Veeam Backup & Replication or Commvault Complete Backup & Recovery	Provides comprehensive data protection by creating backup copies of critical data and applications. Offers features such as encryption and flexible recovery options to minimize data loss and downtime during disaster recovery scenarios.
Cloud Disaster Recovery Service	Azure Site Recovery or AWS Disaster Recovery	Enable replication of workloads and data to the cloud for rapid recovery in the event of on-premises failures or disasters. They

		offer automated failover, scalability, and cost-effective disaster recovery solutions.
Data Replication Software	Zerto or VMware vSphere Replication	Replicates data in real-time or near-real-time between multiple locations or data centers. Ensures data availability and resiliency by maintaining synchronized copies of critical data across geographically dispersed sites.
Server Virtualization Platform	VMware vSphere or Microsoft Hyper-V	Enable consolidation of server workloads, improves resource utilization, and facilitates rapid provisioning of virtual machines during disaster recovery scenarios. They offer features such as high availability and live migration to enhance workload mobility and resilience.
Network and Application Monitoring Tool	SolarWinds Network Performance Monitor or Nagios Core	Provides real-time visibility into network infrastructure and application performance. Detects anomalies, identifies potential issues, and facilitates proactive incident response to minimize service disruptions and downtime.
Incident Response Management System	ServiceNow Security Incident Response or IBM Resilient	Provides centralized platforms for managing security incidents from detection through resolution. Facilitates collaboration among incident response teams, tracks incident progress, and ensures timely remediation.
Communication and Collaboration Platform	Slack or Microsoft Teams	Facilitates real-time communication and

		information sharing among disaster recovery and incident response teams. Enables rapid decision-making, coordination of response efforts, and documentation of incident details.
Business Continuity Planning Software	BCP Builder or Assurance Software	Helps organizations develop and maintain comprehensive business continuity plans. Provides templates, workflows, and risk assessment tools to streamline the business continuity planning process and ensure readiness for disaster recovery scenarios.

Figure 11. Software Recommendations and Purposes

5.8 CPMT ESTABLISHMENT

Below is a flow-chart representing the Contingency Planning Management Team:

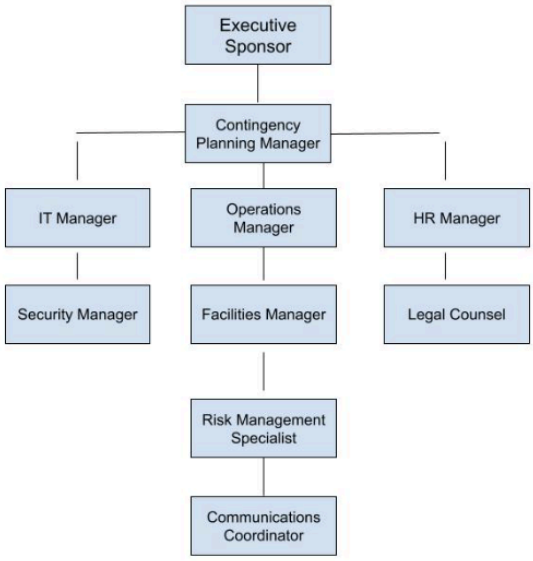

Figure 12. CPMT Flow-Chart

5.8.1 DECISION MAKERS

All members in a team highlighted in the flow chart above must work together to find solutions that are acceptable to everyone involved. Decisions are informed by the expertise and knowledge of individual team members. Each member brings a unique perspective and skill set to the table, contributing valuable insights to the decision-making process. Individual role descriptions are illustrated below:

Executive Sponsor: This individual provides overall strategic direction, support, and resources for the disaster recovery plan. They are typically a high-level executive responsible for ensuring that the plan aligns with business objectives and priorities.

Contingency Planning Manager: This person is responsible for overseeing the development, implementation, and maintenance of the disaster recovery plan. They coordinate the activities of various stakeholders and ensure that the plan is comprehensive and effective.

IT Manager, Operations Manager, HR Manager, Security Manager, Facilities Manager, Legal Counsel: These departmental managers are responsible for providing expertise and support in their respective areas. They contribute to the development of contingency plans specific to their departments and ensure alignment with overall organizational goals.

Risk Management Specialist: This individual assesses potential risks and threats to the organization and develops mitigation strategies to address them. They provide input on risk assessment and risk management strategies within the context of the disaster recovery plan.

Communications Coordinator: This person is responsible for coordinating internal and external communications during a disaster or emergency situation. They ensure that stakeholders are kept informed and updated on the status of recovery efforts.

5.9 POTENTIAL UPDATES TO INCIDENT RESPONSE LIFECYCLE

During the investigation phase of the incident response life cycle, the primary objective is to gather information, analyze data, and determine the scope and severity of the incident. An incident response team should be delegated by the company to come into action upon detection of an incident. They will assess the situation and prioritize response efforts based on the potential impact on critical systems and data. Relevant evidence, including log files, network traffic captures, system snapshots, and any other pertinent data, is collected to aid in the investigation process. Forensic techniques and tools will be utilized in the investigation process by

professionals to analyze the collected evidence, identify indicators of compromise, and uncover the root cause of the incident. Finally, effective communication between all members of the incident response team and other relevant parties such as stakeholders are crucial to ensure a cohesive and efficient response effort throughout the investigation phase.

As cyber threats continue to evolve and become more sophisticated, it is essential to regularly review and update the incident response life cycle as depicted above to adapt to emerging challenges and improve response capabilities. Conducting regular incident simulation exercises and providing ongoing training to incident response team members can help improve preparedness, response times, and decision-making skills in real-world scenarios; and keep each member up to date of the latest updates to the cycle. Regularly evaluating incident response processes, procedures, and tools, and incorporating lessons learned from past incidents will help team members and the company optimize their incident response program.

6.0 Policies and Controls

6.1 PURPOSE

The establishment of comprehensive information security policies and controls is essential for Shameless's ongoing success. As a company operating in the cyber field, Shameless relies heavily on digital technologies and data-driven processes. This reliance on technology exposes Shameless to various cybersecurity threats, including data breaches, insider threats, malware attacks, and regulatory non-compliance. Effective policies and controls serve as the cornerstone of Shameless's cybersecurity strategy, providing clear guidance, standards, and procedures to safeguard its critical assets, mitigate risks, and ensure business continuity. By creating policies that outline the organization's commitment to protecting sensitive information, complying with relevant laws and regulations, and maintaining the CIA of data, Shameless demonstrates its dedication to safeguarding information assets. Aligning with industry-standard controls creates greater trust between customers and partners while also minimizing disruptions and haltages to business processes.

6.2 DEFINITIONS

When developing a policy design, it is essential to understand the different components that allow the policy to function. Along with the policy statement, standards, best-practice, and procedures must be understood. Descriptions for each are defined below to ensure that a newly-implemented policy is properly analyzed and enforced.

6.2.1 POLICY DEFINITION

Policies are high-level statements that display the organization's intentions, objectives, and principles regarding information security. These statements provide a framework for decision-making and guide employees on acceptable behaviors and actions. They typically outline the organization's commitment to protecting its assets, complying with relevant laws and regulations, and maintaining the CIA of data. They serve as the foundation for developing more detailed standards, procedures, and guidelines within the organization.

6.2.2 STANDARDS DEFINITION

Standards provide a more detailed criteria that must be met to achieve specific policy objectives within the organization. Unlike policies, which are generally broad statements, standards provide specific requirements and guidelines for implementing security controls, processes, and technologies. They help ensure consistency and quality in the

organization's information security practices. Defining standards of a policy helps ensure that relevant employees are able to carry it out, creating a safe and informed environment.

6.2.3 BEST-PRACTICE DEFINITION

Best-practices are proven methods, techniques, or approaches that have been demonstrated to produce successful results in a particular context. In the context of information security, this includes industry-recognized norms or benchmarks for achieving effective security outcomes. These practices are formulated through security professionals in the field, along with regulatory bodies like NIST. Implementing best-practices can help organizations enhance their security posture and reduce vulnerabilities, preparing them against evolving cyber threats.

6.2.4 PROCEDURES DEFINITION

Procedures are detailed, step-by-step instructions for carrying out specific tasks or processes within the organization. Unlike policies and standards, which generally provide high-level guidance and requirements, procedures offer operational guidance and specify the actions that employees must take to achieve desired outcomes. Detailed instructions for carrying out day-to-day policies are provided, usually in a handbook or another easily-accessible document. Defining procedures to employees is essential in ensuring consistency, efficiency, and compliance with organizational policies and standards across the organization.

6.3 TYPES OF INFORMATION SECURITY POLICIES

There are three types of information security policies: Enterprise Information Security Policy (EISP), System-Specific Security Policy (SysSP) and Personnel Security Policy. An EISP serves as the foundation of the organization's information security program, establishing the strategic direction and responsibilities for all members in the organization. It sets a scope and tone for other security measures to follow. This guides the two following types of policy that are more specific and direct with their intentions. A SysSP outlines the specific security requirements, configurations, and controls for individual information systems within the organization. Employees are given a guideline in how to maintain certain systems in order to align with the overall security goals. Authorized users for a system are defined, along with who and what is prohibited on it. A Personnel Security Policy helps define what is expected from employees on a more day-to-day basis. This ensures that all members of the organization are properly following security procedures in terms of their personal use. This includes use of personal devices and personal use on company systems. Each policy serves a distinct role in promoting a comprehensive approach to information security management.

6.4 POLICY RECOMMENDATIONS

6.4.1 PHISHING AWARENESS AND EMAIL SECURITY POLICY

Given the incident involving phishing emails targeting senior staff members and the subsequent malware attacks, implementing a policy focused on phishing awareness and email security is crucial. The Emotet malware was installed on company systems likely due to spear phishing. Furthermore, a separate incident resulted in the leaking of over ~1000 customer's personal data. As explained in section 3.8 of this ISMS, this single instance could cause thousands of dollars in fines. Furthermore, company reputation could be heavily harmed as the information was released to the public. The purpose of this policy is to educate employees about the risks associated with phishing attacks and to establish guidelines for identifying and mitigating email threats to protect organizational data and systems. This policy will apply to all employees and third-party vendors who have access to the organization's email systems.

6.4.2 PATCH MANAGEMENT POLICY

Shameless has experienced multiple incidents where known vulnerabilities in software systems, such as the Zerologon bug and unpatched Microsoft Exchange server, have been exploited by attackers. It is known which patches needed to be applied to the system, but ignorance over the matter invites unwarranted access to important information. Cyber threats are constantly evolving, and updated systems are essential in order to stay ahead of these hackers. Downtime due to these unresolved patches can cause hundreds of thousands of dollars in loss. As seen by the estimate from a recent upgrade to the system, about $200,000 was lost in two days as a result of downtime. The purpose of this policy is to establish procedures for identifying, prioritizing, and applying software patches and updates to mitigate known vulnerabilities and reduce the organization's exposure to threats.

6.4.3 DATA ENCRYPTION POLICY

The theft of a laptop containing sensitive client data highlights the importance of data protection, particularly when devices are used outside the office premises. A data encryption policy would require the encryption of sensitive data stored on mobile devices and laptops to prevent unauthorized access in the event of theft or loss. Most incidents occur unintentionally and cases of theft can be hard to account for, but encryption of data ensures that losses in this event are minimized. This policy will apply to all electronic devices, storage media, and communication channels used to store or transmit sensitive data within the organization.

6.4.4 DISASTER RECOVERY AND BUSINESS CONTINUITY POLICY

Shameless has experienced data losses due to hardware failures and inadequate disaster recovery measures, leading to significant operational disruptions and financial losses. A recovery and business continuity policy is essential to ensure the organization's ability to recover critical systems and data in the event of disasters. The definition of a disaster event is described in section 5.4.4 of the ISMS. It includes who should be involved in the DRT and when to escalate measures. Furthermore, section 5.7 highlights the process the DRT should follow and how to limit losses in the event. A policy would solidify the process outlined in this ISMS, ensuring proper measurements are actually taken and people are held accountable. This will also ensure that the correct protocols are reciprocated to the entire organization. This policy would outline procedures for data backup, system recovery, alternative work arrangements, and regular testing of disaster recovery plans to minimize downtime and the impact of disruptions on business operations.

6.4.5 ISO 27001 CONNECTION

The ISO 27001 is an international standard for information security management. They provide a list of controls for companies to follow for easier implementation of security policies. Below is a table that connects these policies to specific policies, along with justifications for each:

Recommended Policy	ISO 27001 Control	Justification
Phishing Awareness/Email Security	6.3 (Information security awareness, education and training)	This policy aligns with training employees to understanding email attacks and how to recognize them
Patch Management	8.7 (Protection against malware), 8.8 (Management of technical vulnerabilities), 8.12 (Data leakage prevention)	This policy aligns with all these controls. Managing known vulnerabilities will in turn protect against malware and prevent data leakage.
Data Encryption	8.2 (Privileged access rights), 8.11 (Data masking), 8.20 (Networks security)	This policy aligns with these controls by only allowing specific users to have access to encrypted data, along with

		network security provided by encryption.
Disaster Recovery/Business Continuity	5.4 (Management responsibilities), 5.26 (Response to information security incidents), 7.10 (Storage media)	This policy aligns with these controls as responsibilities of each member must be known, along with how to respond and protect stored data.

Figure 13. ISO Controls and Policy Justification

Phishing Awareness and Email Security Policy

Created for: Shameless Ltd.

Created by: Gill Ltd.

Version 1.2

Date: 05/08/2024

Template provided by SANS Institute
(https://www.sans.org/information-security-policy/?page=2)

OVERVIEW

Emails are often used in the business setting for communication and transmittance of data. Misuse of email can post many legal, privacy and security risks, emphasizing the importance for users to understand the appropriate use of electronic communications. Scams can be sent to Shameless email accounts, often in the form of phishing attacks that masquerade in order to compromise company systems. In order to protect Shameless's assets, all employees need to defend the integrity and confidentiality of Shameless's resources.

PURPOSE

The Phishing Awareness and Email Security policy is designed to: communicate to employees what is acceptable in terms of company email use, make employees aware that social engineering attacks occur, and that there are procedures in place for detection of potential scams. Employees will be able to understand their importance at maintaining Shameless's security posture, identify suspicious emails, and who to contact in the case of a potential attack. Furthermore, employees will be able to make the best choice when being pressured into sharing sensitive information.

SCOPE

The scope of the Phishing Awareness and Email Security policy will include all employees of Shameless, along with contractors and agents working on Shameless's behalf.

POLICY

1. All use of email must be consistent with Shameless policies and procedures of ethical conduct, safety, compliance with applicable laws and proper business practices.
2. Shameless email accounts should be used primarily for Shameless business related purposes; personal communication is permitted on a limited basis, but non-Shameless related commercial uses are prohibited.
3. Shameless may monitor messages without prior notice. Shameless is not obliged to monitor email messages.
4. Users are prohibited from automatically forwarding Shameless emails to a third party email system. Individual messages which are forwarded by the user must not contain Shameless confidential information.
5. Sensitive information of Shameless will not be shared with an unauthorized individual.
    a. Techniques and phrases like "urgent matter" or threatening from "higher-level management" will not sway Shameless employees into sending information.

   b. Requests to release information about Shameless resources to a third-party will not be obeyed.
   c. Methods like ego and vanity persuasion through email will not allow for sharing of Shameless information.
6. URL links sent to a Shameless email will not be accessed without proper evaluation of the sender and information provided in the email.
   a. Personal information will not be shared through one of these links, especially regarding Shameless information.
7. Employees must complete a Phishing Awareness course within 30 days of employment. Employees must pass subsequent exam, or must retake until passing with an acceptable score. The course must be taken every six months by those outlined in the scope, along with the passing of any subsequent exam.
8. If any person defined under the scope examines email behavior mentioned in number 5 or 6 above, the identity of the requester MUST be determined before continuing communication. If unable, the Help Desk has to be contacted. The Help Desk must contact the Head of IT if suspicious activity is confirmed.
   a. In the case the Help Desk is unavailable, the supervisor must be contacted before the end of the business day. If the supervisor is unavailable, the Head of IT must be contacted before the end of the business day.

POLICY COMPLIANCE

Monitoring compliance of the Phishing Awareness and Email Security policy includes periodic walk-thrus, video monitoring, business tool reports, internal and external audits, and feedback to the policy owner. Fake emails will be sent periodically in order to gauge the response of employees. A six-month renewal is required by each employee to ensure the policy is being followed and understood. Any exception to the above policy must be approved by the information security team in advance. Failure to comply with the above policy will result in disciplinary action. Purposeful ignorance to potential phishing emails can lead to permanent termination of employment, depending on frequency and severity.

VERSION HISTORY

Date	Author	Version	Description
05/03/2024	Sampy Gill	1.0	Created title page and outline of subsection
05/05/2024	Sampy Gill	1.1	Completed Overview, Purpose, and Scope subsections

05/06/2024	Sampy Gill	1.2	Completed Policy, Policy Compliance subsections

Patch Management Policy

Created for: Shameless Ltd.

Created by: Gill Ltd.

Version 1.3

Date: 05/08/2024

Template provided by SANS Institute
(https://www.sans.org/information-security-policy/?page=2)

OVERVIEW

Unsecured and vulnerable servers continue to be a major entry point for malicious threat actors. Known vulnerabilities allow for known exploitations to be performed on potentially sensitive Shameless systems. Timely and effective patch management is essential for mitigating these risks and maintaining the security posture of Shameless. This policy outlines the responsibilities for identifying, prioritizing, and applying software patches and updates across the organization's information systems.

PURPOSE

The purpose of the Patch Management policy is to establish standards for the base updating measures of internal server equipment that is owned and/or operated by Shameless. Employees will be able to understand the importance of ensuring systems are up-to-date and the impact not doing so can have on Shameless. Effective implementation of this policy will minimize unauthorized access to Shameless proprietary information and technology. Data losses will be mitigated, along with the assurance that business operations won't suffer from out of date technology and systems.

SCOPE

All employees, contractors, consultants, temporary and other workers at Shameless and its subsidiaries must adhere to this policy. This policy applies to server equipment and systems that are owned, operated, or leased by Shameless or registered under a Shameless-owned internal network domain.

POLICY

1. All internal servers and systems deployed at Shameless must be owned by an operational group that is responsible for system administration. Approved server/system updating guides must be established and maintained by each operational group, based on business needs, and approved by the information security team. Operational groups should monitor configuration compliance and implement an exception policy tailored to their environment. Each operational group must establish a process for changing the configuration guides, which includes review and approval by the information security team.
2. Servers and systems must be registered within the corporate enterprise management system. At a minimum, the following information is required to positively identify the point of contact:
    a. Server contacts and location, along with backup contacts

   b. Hardware and Operating System information, including type, version, update date, etc.
   c. Main functions and applications of the server/system
3. Information provided to the enterprise management system must be kept up-to-date and organized for easy accessibility by authorized users.
4. Shameless will utilize automated vulnerability scanning tools to identify missing patches and security vulnerabilities across its information systems.
   a. The Help Desk will be responsible for monitoring these systems, along with aid of the Head of IT when applicable.
   b. Vulnerabilities will be prioritized based on severity ratings, exploitability, and potential impact on business operations. (refer to risk register to understand severity calculations)
5. Prior to deployment, patches will undergo testing in a controlled environment to assess compatibility and verify that they do not introduce new issues or conflicts.
   a. Patch deployment schedules will be established based on the criticality of the vulnerability, with priority given to critical and high-risk patches.
6. System administrators will be tasked with applying patches to their respective systems and documenting patching activities.
   a. Comprehensive documentation of patch management activities, including patch identification, testing results, deployment schedules, and verification records, will be maintained.
7. Services and applications that will not be used must be disabled where practical.
8. Servers and systems should be physically located in an access-controlled, secured environment.

POLICY COMPLIANCE

Compliance with the Patch Management Policy will be monitored by the information security team through periodic vulnerability assessments, patch deployment reports, and internal audits. To assess employee awareness and adherence to the policy, simulated patching exercises may be conducted periodically to gauge response and compliance. Non-compliance with the Patch Management Policy may result in disciplinary action, including warnings, training requirements, or termination of employment, depending on the severity and frequency of violations.

VERSION HISTORY

Date	Author	Version	Description
05/05/2024	Sampy Gill	1.0	Created title page and outline of subsection

05/05/2024	Sampy Gill	1.1	Completed Overview, Purpose, and Scope subsections
05/06/2024	Sampy Gill	1.2	Worked on Policy subsection
05/08/2024	Sampy Gill	1.3	Completed Policy and Policy Compliance subsections

Phishing Awareness Training and Email Response Procedure

Created for: Shameless Ltd.

Created by: Gill Ltd.

Version 1.2

Date: 05/08/2024

PURPOSE

Email remains one of the most commonly exploited attack methods by threat actors seeking unauthorized access to sensitive information or corporate networks. Furthermore, phishing attacks continue to evolve in complexity and frequency, posing significant risks to organizational security. This procedure seeks to raise awareness among employees about the importance of email security and the critical role they play in safeguarding organizational assets.

PROCEDURE STEPS

1. **PHISHING AWARENESS TRAINING**

    a. The information security team will develop a training program in order to educate employees about potential threats and attack vectors. This program will tailor to the needs of Shameless employees in particular.
    b. First, a message recognizing the frequency and threat of phishing emails will be sent out to the entire organization. An emphasis will be put on recent incidents occurring to Shameless directly, stating actual losses the company went through and how this can impact each and every employee. This message must be signed by each employee, ensuring that everyone has read the memo and made aware of the ongoing threat posed by phishing.
    c. An initial knowledge test will be sent out to every employee, and average scores from each department will be evaluated to gauge the current status of awareness. This knowledge test will include simple terms and definitions to see if employees know what phishing is and what can cause compromises through email.
    d. The information security team will then implement a phishing awareness training tool to be used by every employee in Shameless. While many programs are available for use, a gamified approach will allow all employees with not much knowledge in the area to be engaged and learn.
    e. The ESET Cybersecurity Awareness Training is an industry-leading program used by many different organizations. Content includes games and role-playing for an engaging experience. Administrators can modify quizzes and modules in order to tailor to Shameless's needs. Specific users from different departments can be grouped together depending on where emphasis is needed. Courses take less than 90 minutes, making it practical for potential daily use. Furthermore, a plug-in is provided in order to report suspicious emails. This includes fake ones, and users can be monitored on how effectively they can detect a phishing attack. The application is user-friendly and easy to navigate, creating an effective way to continuously monitor email security needs (see figure 14 below).

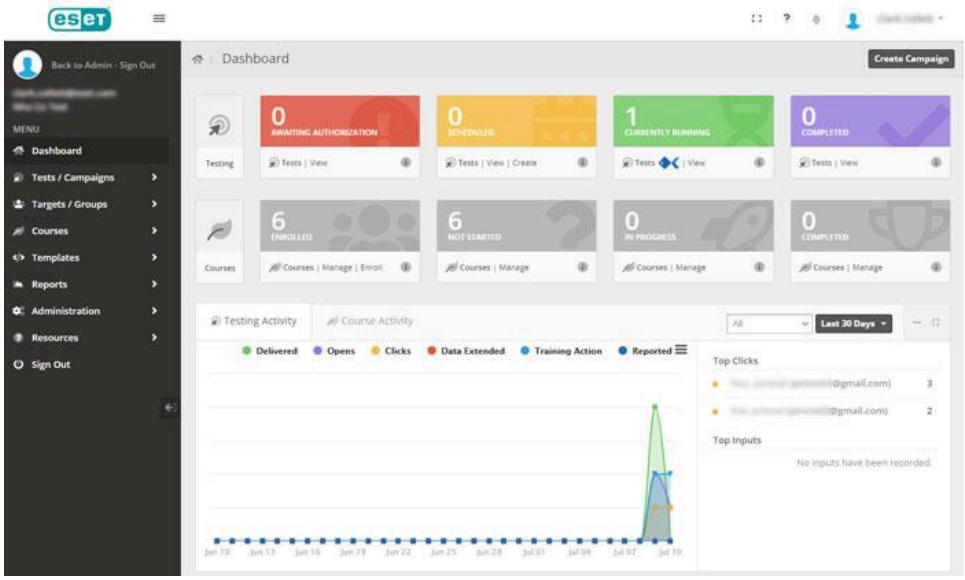

Figure 14. ESET Dashboard

2. PROTOCOLS FOR REPORTING AND RESPONSE

a. The information security team will develop a proper channel of communication in order to effectively report potential phishing attacks. Employees will be informed of the procedures for reporting suspected emails to the security team, including the designated email address or reporting portal to use and any additional information required for effective incident response.
b. Reports must include the sender's email address, content of the email, any links or URLS included, and reasons why the employee is suspicious.
c. These forms of communication will be posted in easily-accessible locations throughout the organization's offices. The specified email or portal will only be used for reporting purposes. Furthermore, if the ESET program is implemented, another channel of communication will be made available.
d. The Help Desk will be responsible for analyzing reports made by other employees. The sender of the email will be verified or not, prompting further response if needed. If it cannot be concluded, the Head of IT may be involved. Law enforcement may have to get involved, but under the guidelines provided in section 5.4.5 of the ISMS.
e. Employees will receive timely feedback and updates on the status of reported phishing incidents, including any remediation measures taken to mitigate the risk of further exposure or compromise.
f. Confirmed attacks will be relayed to the entire organization, ensuring the same sender isn't attempting to compromise others at Shameless.

g. Reports will be archived for a minimum of a year, making sure that subsequent attack attempts aren't connected.

VERSION HISTORY

Date	Author	Version	Description
05/08/2024	Sampy Gill	1.0	Created title page and outline of subsection
05/08/2024	Sampy Gill	1.1	Completed Purpose and Procedure Steps subsection

References

California, S. of. (n.d.). California Consumer Privacy Act Regulations. California Consumer Privacy Act Regulations - California Privacy Protection Agency (CPPA). https://cppa.ca.gov/regulations/consumer_privacy_act.html

Computer Security Division, I. T. L. (n.d.). Access CPRT - cybersecurity and privacy reference tool: CSRC. CSRC. https://csrc.nist.gov/projects/cprt/catalog#/cprt/framework/version/SP_800_53_5_1_1/home

"Cybersecurity Awareness Training." ESET, 2023, www.eset.com/us/business/cybersecurity-awareness-training/?utm_source=bing&utm_m

Cybersecurity Framework Components. NIST. (2023, March 16). https://www.nist.gov/cyberframework/online-learning/cybersecurity-framework-components

Dempsey, K., Chawla, N., Johnson, L., Johnston, R., Jones, A., Orebaugh, A., Scholl, M., & Stine, K. (2011, September 30). Information Security Continuous Monitoring (ISCM) for federal information systems and Organizations. CSRC. https://csrc.nist.gov/pubs/sp/800/137/final

Digital Personal Data Protection act 2023 | Ministry of Electronics ... (n.d.). https://www.meity.gov.in/content/digital-personal-data-protection-act-2023

Document library. PCI Security Standards Council. (2023, December 1). https://www.pcisecuritystandards.org/document_library/

Editor, C. C. (n.d.). Asset - glossary: CSRC. CSRC Content Editor. https://csrc.nist.gov/glossary/term/asset

Force, J. T. (2020a, December 10). Security and Privacy Controls for Information Systems and organizations. CSRC. https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final

Force, J. T. (2020b, December 10). Security and Privacy Controls for Information Systems and organizations. CSRC. https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final

India enacts a comprehensive data privacy law: The Digital Personal Data Protection act. Bass, Berry & Sims PLC. (2023, October 16). https://www.bassberry.com/news/india-digital-personal-data-protection-act/

Initiative, J. T. F. T. (2012, September 17). Guide for Conducting Risk Assessments. CSRC. https://csrc.nist.gov/pubs/sp/800/30/r1/final

Kissel, R., Regenscheid, A., Scholl, M., & Stine, K. (2014, December 17). Guidelines for Media Sanitization. CSRC. https://csrc.nist.gov/pubs/sp/800/88/r1/final

Official Legal Text. General Data Protection Regulation (GDPR). (2022, September 27). https://gdpr-info.eu/

"Security Policy Templates." Information Security Policy Templates | SANS Institute, 2024, www.sans.org/information-security-policy/?category=application-security%2Cgeneral%2Cserver-security%2Cnetwork-security%2Cretired&page=5.

Stine, K., Kissel, R., Barker, W., Lee, A., & Fahlsing, J. (2008, August 1). Guide for mapping types of information and information systems to security categories: Appendices. CSRC. https://csrc.nist.gov/pubs/sp/800/60/v2/r1/final

Swanson, M., Hash, J., & Bowen, P. (2006, February 24). Guide for developing security plans for Federal Information Systems. CSRC. https://csrc.nist.gov/pubs/sp/800/18/r1/final